

HACKER ATTACK

WEB HACKING FUNDAMENTALS



14

LISTA DE FIGURAS

Figura 1 – Importando máquina de estudos web (1)	7
Figura 2 – Importando máquina de estudos web (2)	8
Figura 3 – Importando máquina de estudos web (3)	8
Figura 4 – Criando rede específica (1)	9
Figura 5 – Criando rede específica (2)	9
Figura 6 – Criando rede específica (3)	10
Figura 7 – Configurando interface de rede (1)	11
Figura 8 – Configurando interface de rede (2)	11
Figura 9 – Configurando interface de rede (3)	11
Figura 10 – <i>Startando</i> Máquinas Virtuais (1)	12
Figura 11 – <i>Startando</i> Máquinas Virtuais (2)	13
Figura 12 – Instalação do Gobuster	14
Figura 13 – Instalação Nikto	15
Figura 14 – Instalação FoxyProxy(1)	16
Figura 15 – Instalação FoxyProxy(2)	17
Figura 16 – Instalação FoxyProxy(3)	17
Figura 17 – Instalação FoxyProxy(4)	17
Figura 18 – Instalação FoxyProxy(5)	18
Figura 19 – Instalação FoxyProxy(6)	18
Figura 20 – Instalação FoxyProxy(7)	19
Figura 21 – Instalação Cookie Manager (1)	20
Figura 22 – Instalação Cookie Manager (2)	20
Figura 23 – Instalação Cookie Manager (3)	21
Figura 24 – Instalação Cookie Manager (4)	21
Figura 25 – BurpSuite(1)	22
Figura 26 – BurpSuite(2)	23
Figura 27 – BurpSuite(3)	23
Figura 28 – BurpSuite(4)	24
Figura 29 – BurpSuite(5)	24
Figura 30 – BurpSuite(6)	25
Figura 31 – BurpSuite(7)	25
Figura 32 – BurpSuite(8)	26
Figura 33 – BurpSuite(9)	26
Figura 34 – BurpSuite (10)	26
Figura 35 – BurpSuite(11)	27
Figura 36 – BurpSuite(12)	27
Figura 37 – BurpSuite(13)	28
Figura 38 – BurpSuite(14)	29
Figura 39 – BurpSuite(15)	29
Figura 40 – Identificando Arquivos e Diretórios (1)	30
Figura 41 – Identificando Arquivos e Diretórios (2)	36
Figura 42 – Identificando Arquivos e Diretórios (3)	37
Figura 43 – Identificando Arquivos e Diretórios (4)	44
Figura 44 – Identificando Arquivos e Diretórios (5)	47
Figura 45 – Identificando Arquivos e Diretórios (6)	47
Figura 46 – Identificando Arquivos e Diretórios (7)	50
Figura 47 – Identificando Arquivos e Diretórios (8)	51

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Instalação do Gobuster.....	14
Comando de prompt 2 – Instalação do Nikto	15
Comando de prompt 3 – Instalação Google Chrome	20
Comando de prompt 4 – Identificando Arquivos e Diretórios (1).....	30
Comando de prompt 5 – Identificando Arquivos e Diretórios (2).....	30
Comando de prompt 6 – Identificando Arquivos e Diretórios (3).....	35
Comando de prompt 7 – Identificando Arquivos e Diretórios (4).....	37
Comando de prompt 8 – Identificando Arquivos e Diretórios (5).....	41
Comando de prompt 9 – Identificando Arquivos e Diretórios (6).....	42
Comando de prompt 10 – Identificando Arquivos e Diretórios (7).....	42
Comando de prompt 11 – Identificando Arquivos e Diretórios (8).....	43
Comando de prompt 12 – Identificando Arquivos e Diretórios (9).....	45
Comando de prompt 13 – Identificando Arquivos e Diretórios (10).....	45
Comando de prompt 14 – Identificando Arquivos e Diretórios (11).....	46
Comando de prompt 15 – Identificando Arquivos e Diretórios (12).....	47
Comando de prompt 16 – Identificando Arquivos e Diretórios (13).....	48
Comando de prompt 17 – Identificando Arquivos e Diretórios (14).....	50

SUMÁRIO

1 WEB HACKING FUNDAMENTALS.....	5
1.1 Introdução	5
2 PREPARANDO O AMBIENTE	6
3 BURPSUITE.....	21
4 IDENTIFICANDO ARQUIVOS E DIRETÓRIOS.....	29
4.1 Dirb.....	36
4.2 Gobuster.....	44
4.3 Nikto	49
CONCLUSÃO.....	51
REFERÊNCIAS.....	52

1 WEB HACKING FUNDAMENTALS

1.1 Introdução

Por definição, Pentest em aplicações Web consiste na realização de um teste de invasão, baseando-se na abordagem e estresse dos serviços web, seja de uma plataforma ou serviço.

Para um profissional Pentester, descobrir e mitigar possíveis vulnerabilidades nas aplicações web constitui um dos cernes fundamentais da atividade de segurança, tendo em vista que grande parte dos riscos cibernéticos está concentrada na Internet, ou seja, tem alcance mundial.

Alguns fatores e técnicas contribuem para identificação de vulnerabilidades conhecidas, proporcionando um trabalho organizado e profissional.

Um dos pontos fundamentais para abordagem de um Pentest Web é a utilização de uma metodologia inicial, objetivando a realização de procedimentos padrão e etapas fundamentais, que vão de uma boa enumeração à análise do conteúdo encontrado.

Para uma metodologia básica, o profissional Pentester deve seguir alguns passos iniciais, visando uma direção em sua abordagem, como, por exemplo:

- 1) Análise de código-fonte.
- 2) Enumeração de diretórios.
- 3) Identificação de plataformas empregadas.
- 4) Análise de versões e vulnerabilidades conhecidas.
- 5) Aplicação de técnicas básicas.

Todas essas etapas, ao longo do processo, ficam subentendidas na aplicação das técnicas e no emprego de ferramentas. A metodologia serve apenas como sugestão geral, procurando sempre manter-se dentro de sua linha de atuação.

O Pentest Web, na abordagem do negócio, pode ser comercializado de forma separada ou dentro de uma atuação mais abrangente.

Um dos pontos principais a que o profissional deve atentar-se é o escopo de sua atuação. O escopo norteia as atividades permitidas e o foco final do projeto, evitando desconforto e problemas diversos.

Na análise geral, o teste de vulnerabilidades em aplicações web pode ser definido como um dos produtos mais importantes e fundamentais da atividade de segurança.

No advento da globalização e universo digital, grandes partes das atividades informacionais possuem uma ligação permanente e direta com serviços web.

Na Internet, dados pessoais, informações de rotina, preferências diversas e atividades rotineiras são produtos fundamentais e diretamente ligados ao faturamento.

Diante disso, falhas de segurança em serviços web podem gerar inúmeros prejuízos e danos irreparáveis.

Assim, resumimos toda a importância que a identificação dessas falhas deve possuir.

Neste capítulo, realizaremos uma abordagem sucinta, porém de suma importância no processo de aprendizagem. Tendo em vista que os constantes avanços tecnológicos exigem muito mais empenho e dedicação na absorção de conhecimentos e novos procedimentos.

2 PREPARANDO O AMBIENTE

Para iniciarmos nossos estudos sobre Pentest Web, algumas ferramentas e extensões que serão utilizadas devem ser instaladas, pois elas não vêm por padrão em nosso Kali Linux.

Inicialmente, realizamos o download da imagem .iso, que será objeto de nossa prática e encontra-se disponível no seguinte endereço: <https://fiapcom-my.sharepoint.com/:f/g/personal/pf1221_fiap_com_br/EiT-EC1HMPVGvZAY1XoH-LcBAk5PDxom1cXa_x5FUaeCwQ?e=Uh8r7y>.

Após a realização do download da máquina virtual, objeto de nosso estudo, iniciamos o processo de importação da máquina com o Virtual Box. Primeiramente,

clique com o botão direito na imagem .ova e realize sua importação, conforme as Figuras “Importando máquina de estudos web (1)”, “Importando máquina de estudos web (2)” e “Importando máquina de estudos (3)”.

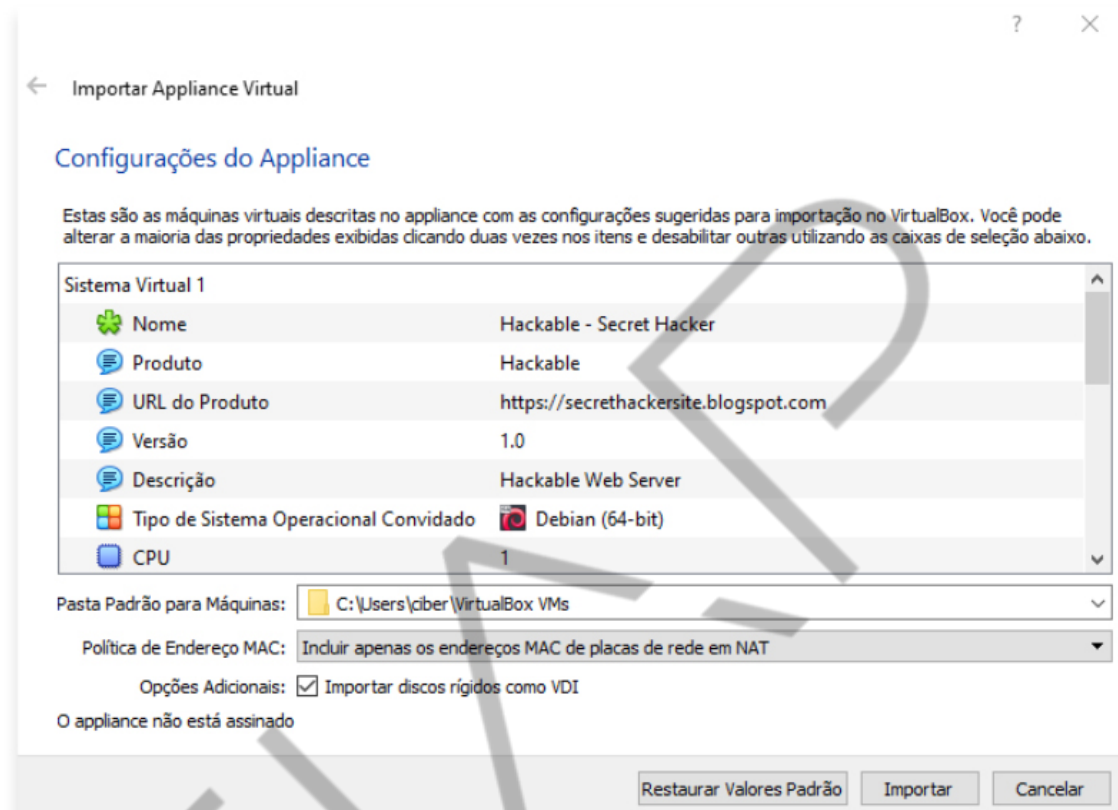


Figura 1 – Importando máquina de estudos web (1)

Fonte: Elaborado pelo autor (2021)

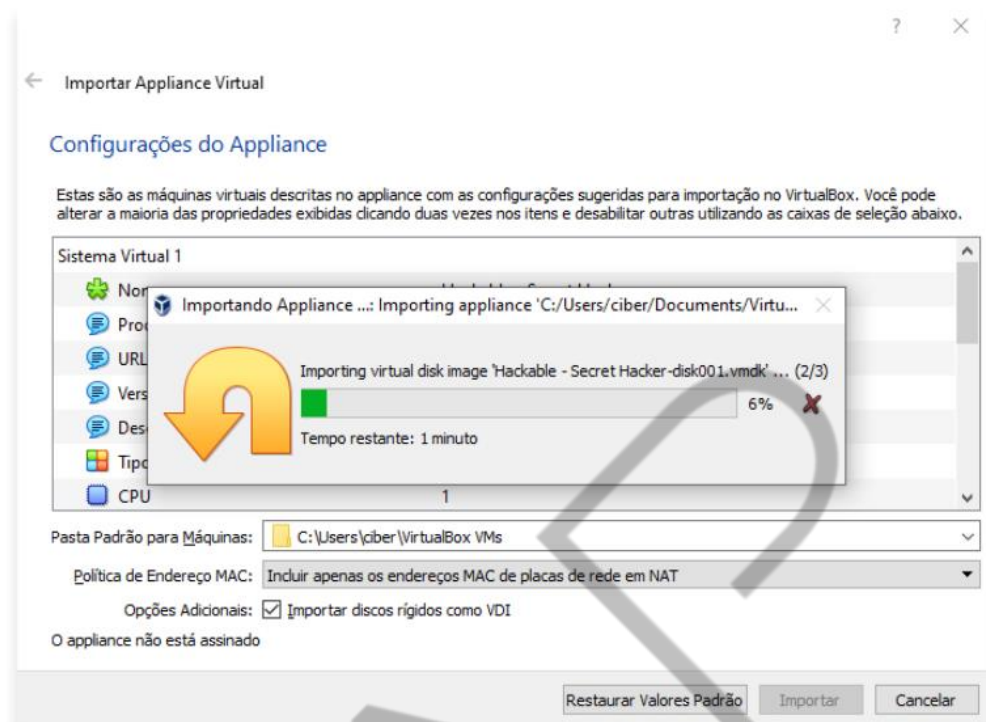


Figura 2 – Importando máquina de estudos web (2)
Fonte: Elaborado pelo autor (2021)

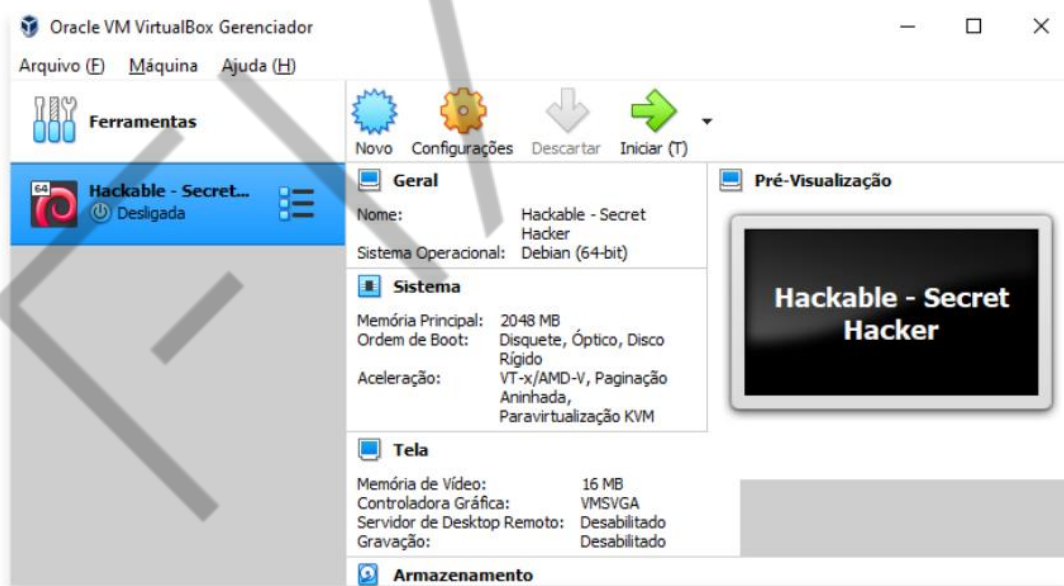


Figura 3 – Importando máquina de estudos web (3)
Fonte: Elaborado pelo autor (2021)

Após a importação da máquina virtual de estudos, iniciamos o processo de configuração da interface de rede, pois as máquinas-alvo e de trabalho deverão estar em um mesmo dispositivo de rede, seguro e segregado. Para tal ação, procedemos com a criação da interface de rede específica do VirtualBox, clicando

em: “Arquivo”, “Host Network Manager”, conforme a Figura “Criando rede específica (1)”.

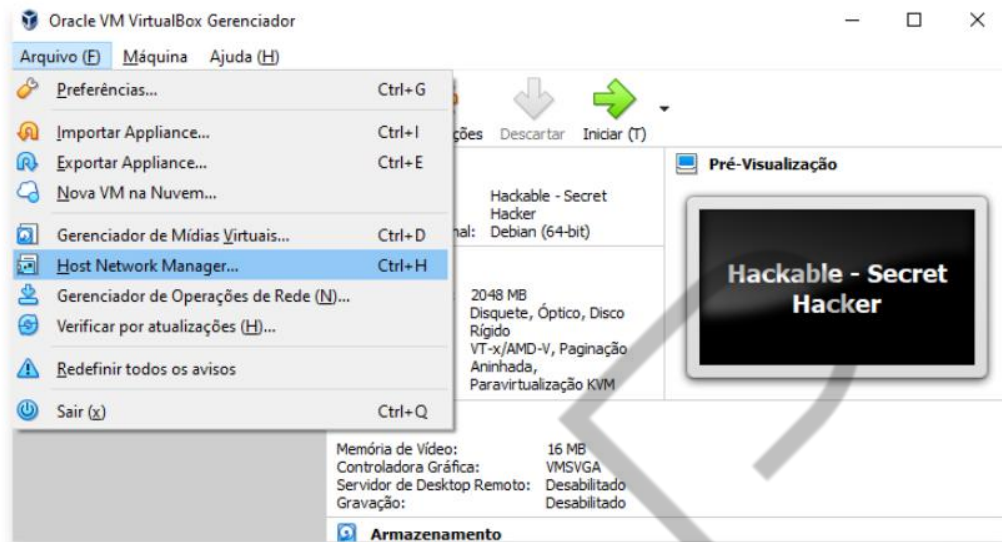


Figura 4 – Criando rede específica (1)
Fonte: Elaborado pelo autor (2021)

Logo após, utilizamos a opção “Criar”, conforme a Figura “Criando rede específica (2)”.

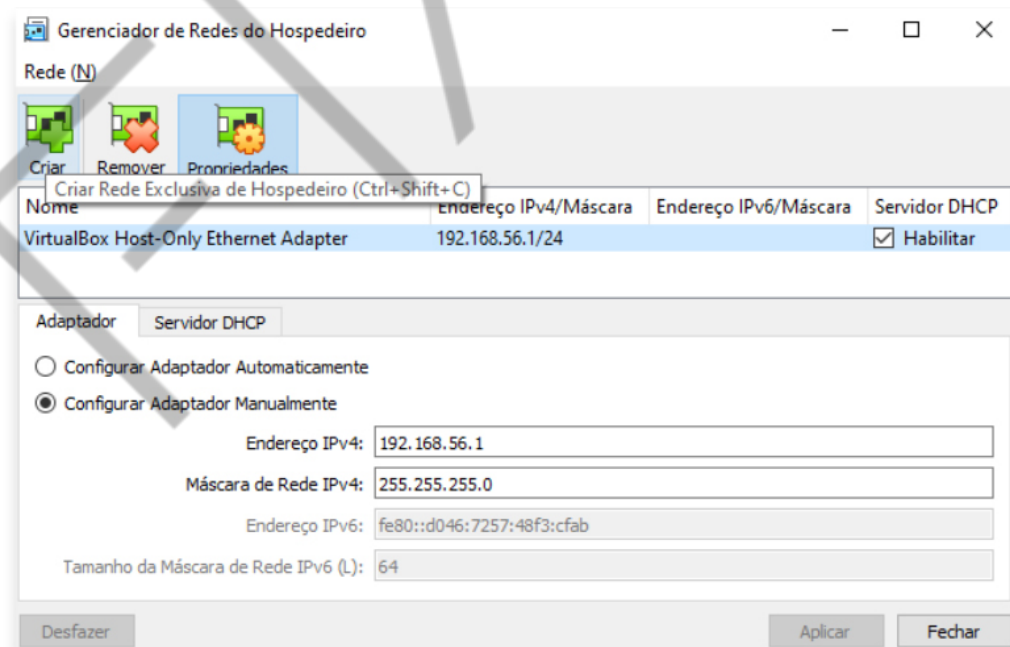


Figura 5 – Criando rede específica (2)
Fonte: Elaborado pelo autor (2021)

Como próximo passo, o VirtualBox irá transcorrer os caminhos para a criação da rede específica e, logo em seguida, verificamos os dados da rede criada, conforme a Figura “Criando rede específica (3)”.

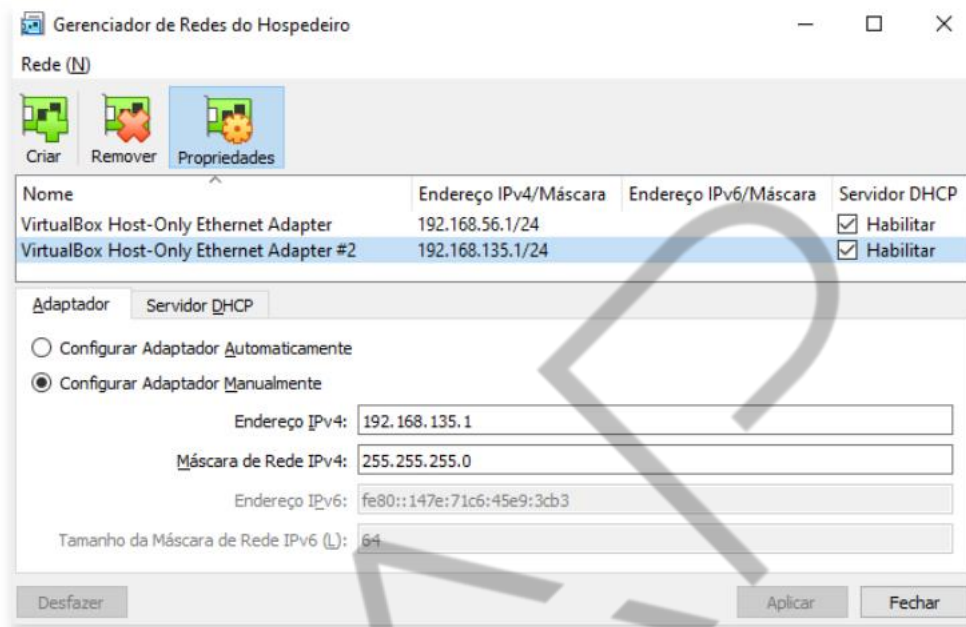


Figura 6 – Criando rede específica (3)

Fonte: Elaborado pelo autor (2021)

Na fase subsequente, atribuímos à interface de rede criada a máquina do laboratório e a máquina de testes web importada, clicando em “Configurações”, “Rede” e selecionando a rede recém-criada, conforme as Figuras “Configurando interface de rede (1)”, “Configurando interface de rede (2)” e “Configurando interface de rede (3)”.

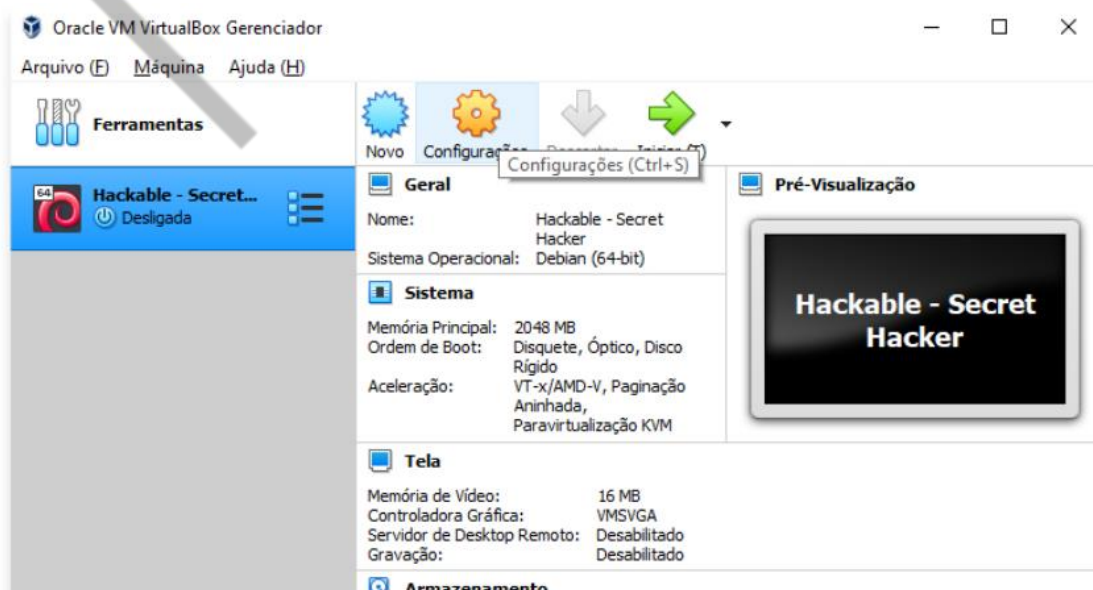


Figura 7 – Configurando interface de rede (1)
Fonte: Elaborado pelo autor (2021)

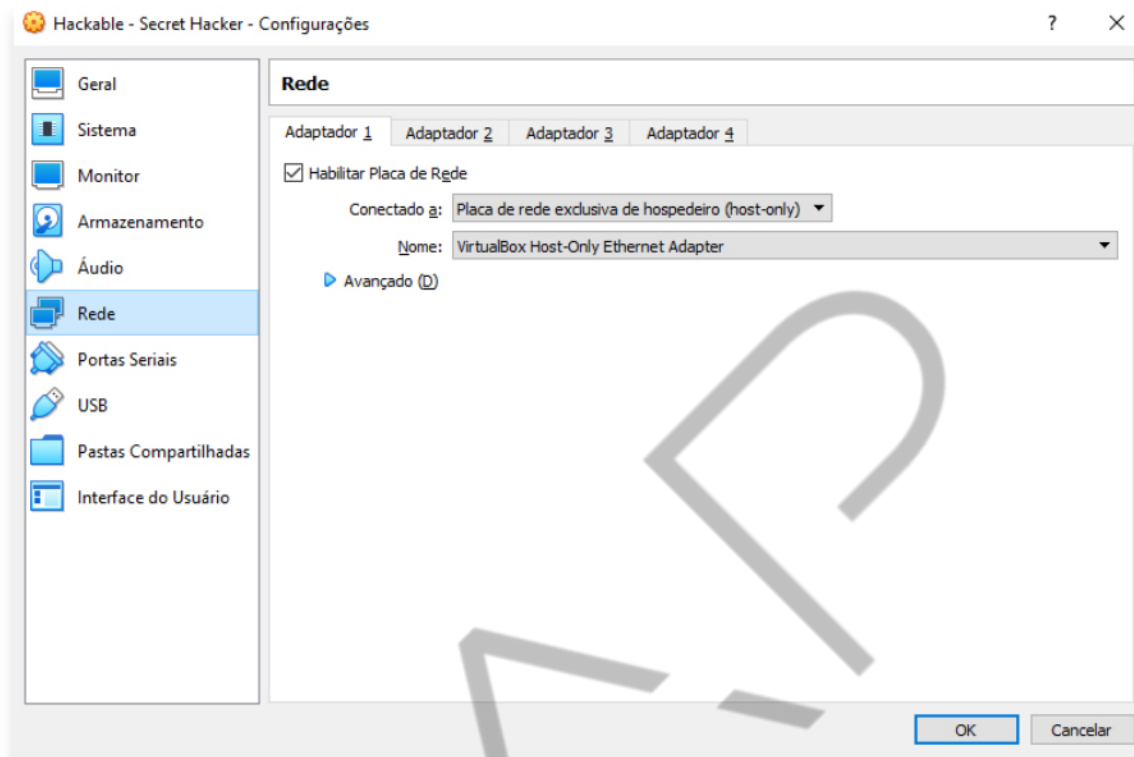


Figura 8 – Configurando interface de rede (2)
Fonte: Elaborado pelo autor (2021)

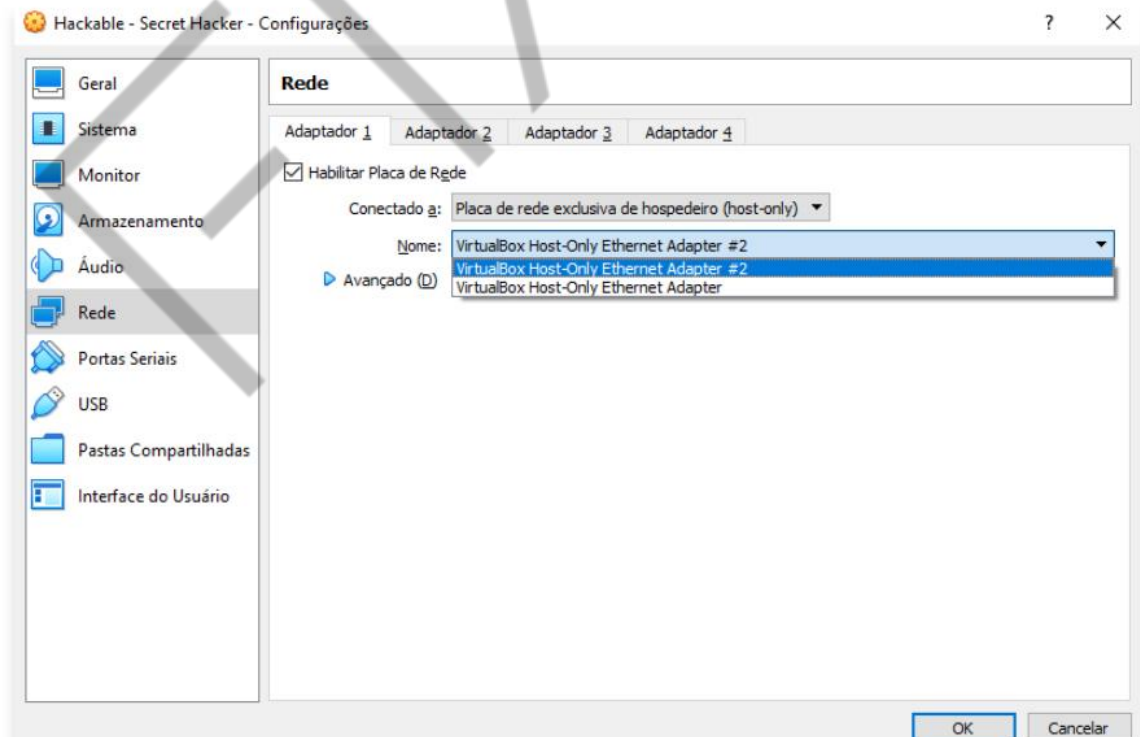


Figura 9 – Configurando interface de rede (3)
Fonte: Elaborado pelo autor (2021)

O mesmo processo de atribuição da interface de rede deve ser realizado na máquina de nosso laboratório.

Com as duas máquinas (Alvo e Base) de nosso laboratório na mesma interface de rede, *startamos* as duas máquinas e procedemos com as atividades, conforme as Figuras “Startando máquinas virtuais (1)” e “Startando máquinas virtuais (2)”.

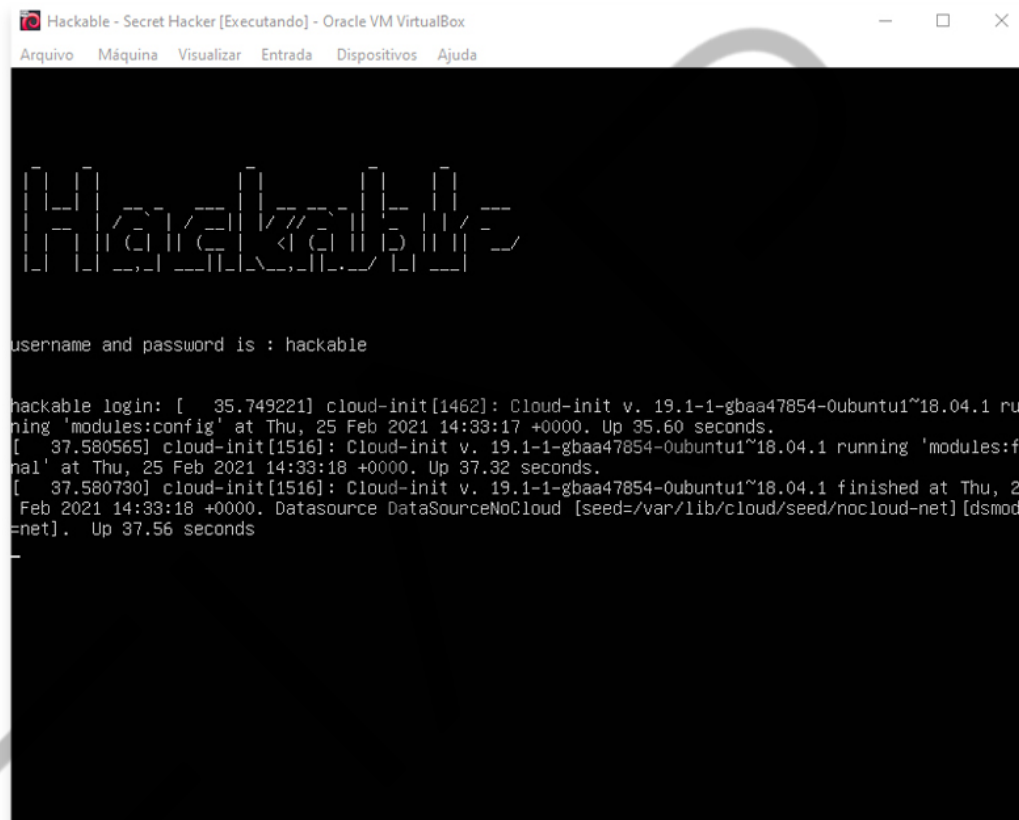


Figura 10 – *Startando Máquinas Virtuais (1)*
Fonte: Elaborado pelo autor (2021)

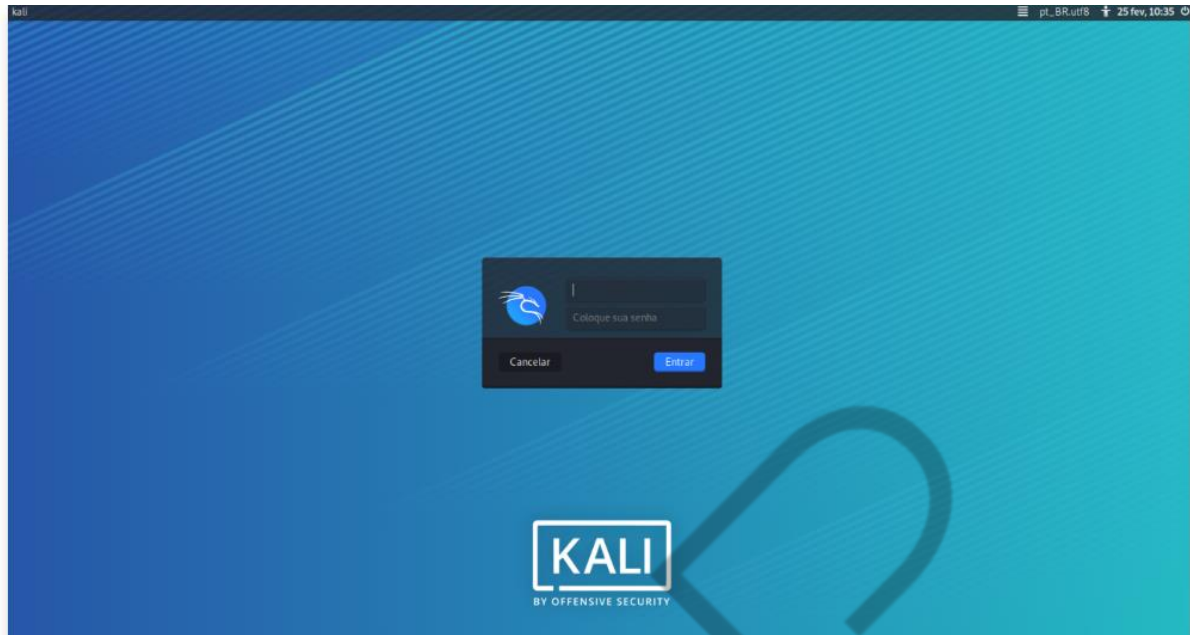


Figura 11 – *Startando Máquinas Virtuais (2)*
Fonte: Elaborado pelo autor (2021)

A máquina virtual do ambiente em questão possui um conjunto de vulnerabilidades web e foi desenvolvida para a execução de uma prática de exploração. Cabe ressaltar que, neste módulo, iremos proceder ao aprendizado das principais e mais recorrentes vulnerabilidades encontradas, porém, o ambiente em questão pode ser utilizado pelo próprio aluno, visando ao desenvolvimento de suas habilidades pessoais.

Como primeiro passo, executamos a instalação da ferramenta Gobuster e do Nikito, que possuem como objetivo a realização de enumeração e identificação de diretórios, arquivos ocultos e plataformas existentes.

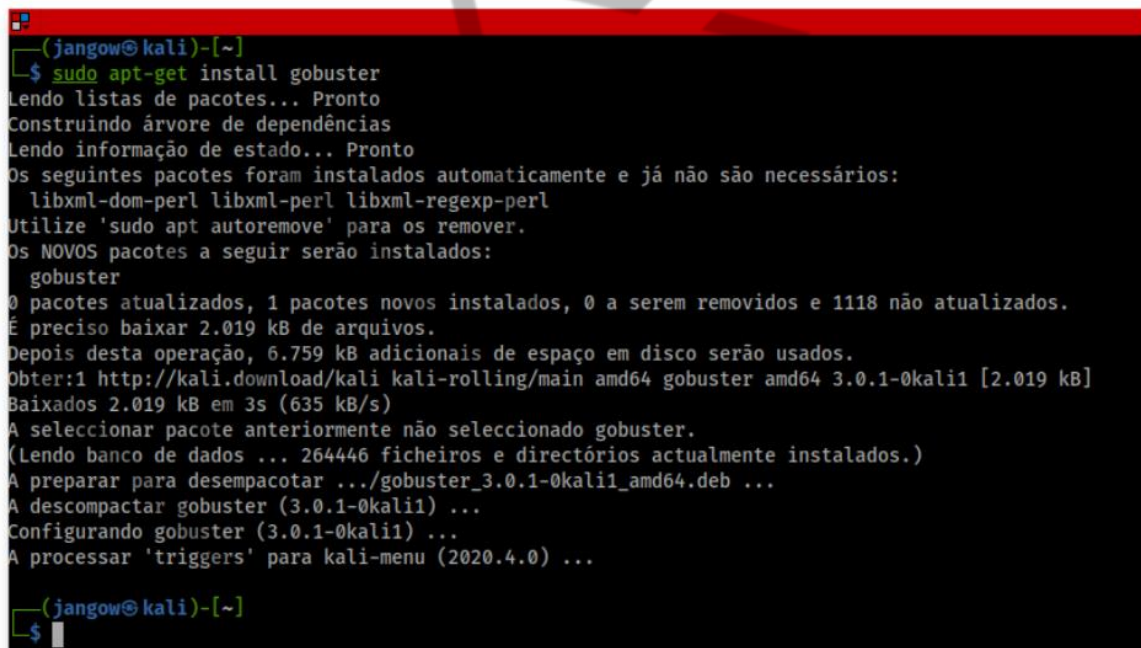
Essas ferramentas contribuem para o processo de enumeração de um serviço ou porta web, pois as combinações de seus parâmetros proporcionam inúmeras formas de abordagem.

Para sua instalação, executamos o Comando de prompt “Instalação do Gobuster”, conforme a Figura “Instalação do Gobuster”.

```
(jangow@kali)~$ sudo apt-get install gobuster
Lendo listas de pacotes... Pronto
Construindo árvore de dependências
Lendo informação de estado... Pronto
Os seguintes pacotes foram instalados automaticamente e já não são necessários:
```

```
libxml-dom-perllibxml-perllibxml-regex-perl
Utilize 'sudo apt autoremove' para os remover.
Os NOVOS pacotes a seguir serão instalados:
gobuster
0 pacotes atualizados, 1 pacotes novos instalados, 0 a serem removidos e 1118 não
atualizados.
É preciso baixar 2.019 kB de arquivos.
Depois desta operação, 6.759 kB adicionais de espaço em disco serão usados.
Obter:1 http://kali.download/kali kali-rolling/main amd64 gobuster amd64 3.0.1-0kali1
[2.019 kB]
Baixados 2.019 kB em 3s (635 kB/s)
A seleccionar pacote anteriormente não seleccionado gobuster.
(Lendo banco de dados ... 264446 ficheiros e directórios actualmente instalados.)
A preparar para desempacotar .../gobuster_3.0.1-0kali1_amd64.deb ...
A descompactar gobuster (3.0.1-0kali1) ...
Configurando gobuster (3.0.1-0kali1) ...
A processar 'triggers' para kali-menu (2020.4.0) ...
```

Comando de prompt 1 – Instalação do Gobuster
Fonte: Elaborado pelo autor (2021)



```
(janguow@kali)-[~]
$ sudo apt-get install gobuster
Lendo listas de pacotes... Pronto
Construindo árvore de dependências
Lendo informação de estado... Pronto
Os seguintes pacotes foram instalados automaticamente e já não são necessários:
  libxml-dom-perl libxml-perl libxml-regex-perl
Utilize 'sudo apt autoremove' para os remover.
Os NOVOS pacotes a seguir serão instalados:
  gobuster
0 pacotes atualizados, 1 pacotes novos instalados, 0 a serem removidos e 1118 não atualizados.
É preciso baixar 2.019 kB de arquivos.
Depois desta operação, 6.759 kB adicionais de espaço em disco serão usados.
Obter:1 http://kali.download/kali kali-rolling/main amd64 gobuster amd64 3.0.1-0kali1 [2.019 kB]
Baixados 2.019 kB em 3s (635 kB/s)
A seleccionar pacote anteriormente não seleccionado gobuster.
(Lendo banco de dados ... 264446 ficheiros e directórios actualmente instalados.)
A preparar para desempacotar .../gobuster_3.0.1-0kali1_amd64.deb ...
A descompactar gobuster (3.0.1-0kali1) ...
Configurando gobuster (3.0.1-0kali1) ...
A processar 'triggers' para kali-menu (2020.4.0) ...

(janguow@kali)-[~]
$
```

Figura 12 – Instalação do Gobuster
Fonte: Elaborado pelo autor (2021)

Logo após a instalação do Gobuster, executamos o Comando de prompt “Instalação do Nikto”, para realização da instalação da ferramenta Nikto, também muito importante na identificação de vulnerabilidades já conhecidas, conforme a Figura “Instalação Nikto”.


```
(jangow@kali)-[~]
└─$ sudo apt-get install nikto      100 x
Lendo listas de pacotes... Pronto
Construindo árvore de dependências
Lendo informação de estado... Pronto
Os seguintes pacotes foram instalados automaticamente e já não são necessários:
libxml-dom-perl libxml-perl libxml-regexp-perl
Utilize 'sudo apt autoremove' para os remover.
Os pacotes a seguir serão atualizados:
nikto
1 pacotes atualizados, 0 pacotes novos instalados, 0 a serem removidos e 1118 não
atualizados.
É preciso baixar 413 kB de arquivos.
Depois desta operação, 0 B adicionais de espaço em disco serão usados.
Obter:1 http://kali.download/kali kali-rolling/non-free amd64 nikto all
1:2.1.6+git20190310-0kali3 [413 kB]
Baixados 413 kB em 5s (88,5 kB/s)
(Lendo banco de dados ... 264446 ficheiros e directórios actualmente instalados.)
A preparar para desempacotar .../nikto_1%3a2.1.6+git20190310-0kali3_all.deb ...
A descompactar nikto (1:2.1.6+git20190310-0kali3) sobre (1:2.1.6+git20190310-0kali2) ...
Configurando nikto (1:2.1.6+git20190310-0kali3) ...
A processar 'triggers' para doc-base (0.11.1) ...
Processing 1 changed doc-base file...
A processar 'triggers' para man-db (2.9.3-2) ...
A processar 'triggers' para kali-menu (2020.4.0) ...
```

Comando de prompt 2 – Instalação do Nikto
Fonte: Elaborado pelo autor (2021)

```
(jangow@kali)-[~]
└─$ sudo apt-get install nikto
Lendo listas de pacotes... Pronto
Construindo árvore de dependências
Lendo informação de estado... Pronto
Os seguintes pacotes foram instalados automaticamente e já não são necessários:
  libxml-dom-perl libxml-perl libxml-regexp-perl
Utilize 'sudo apt autoremove' para os remover.
Os pacotes a seguir serão atualizados:
  nikto
1 pacotes atualizados, 0 pacotes novos instalados, 0 a serem removidos e 1118 não atualizados.
É preciso baixar 413 kB de arquivos.
Depois desta operação, 0 B adicionais de espaço em disco serão usados.
Obter:1 http://kali.download/kali kali-rolling/non-free amd64 nikto all 1:2.1.6+git20190310-0kali3 [413 kB]
Baixados 413 kB em 5s (88,5 kB/s)
(Lendo banco de dados ... 264446 ficheiros e directórios actualmente instalados.)
A preparar para desempacotar .../nikto_1%3a2.1.6+git20190310-0kali3_all.deb ...
A descompactar nikto (1:2.1.6+git20190310-0kali3) sobre (1:2.1.6+git20190310-0kali2) ...
Configurando nikto (1:2.1.6+git20190310-0kali3) ...
A processar 'triggers' para doc-base (0.11.1) ...
Processing 1 changed doc-base file...
A processar 'triggers' para man-db (2.9.3-2) ...
A processar 'triggers' para kali-menu (2020.4.0) ...

(jangow@kali)-[~]
└─$
```

Figura 13 – Instalação Nikto
Fonte: Elaborado pelo autor (2021)

Como próximo passo, e de fundamental importância, iniciamos a instalação e configuração da extensão Fox Proxy, do navegador Firefox. Essa extensão proporcionará a efetiva utilização da ferramenta BurpSuite, que será abordada no próximo tópico. O BurpSuite é empregado em muitas abordagens de Pentest web, facilitando o emprego dos métodos GET e POST.

Para realização desse processo, realizamos uma pesquisa da extensão Foxyproxy na aba “add-ons” do navegador Firefox, conforme a Figura “Instalação FoxyProxy (1)”.

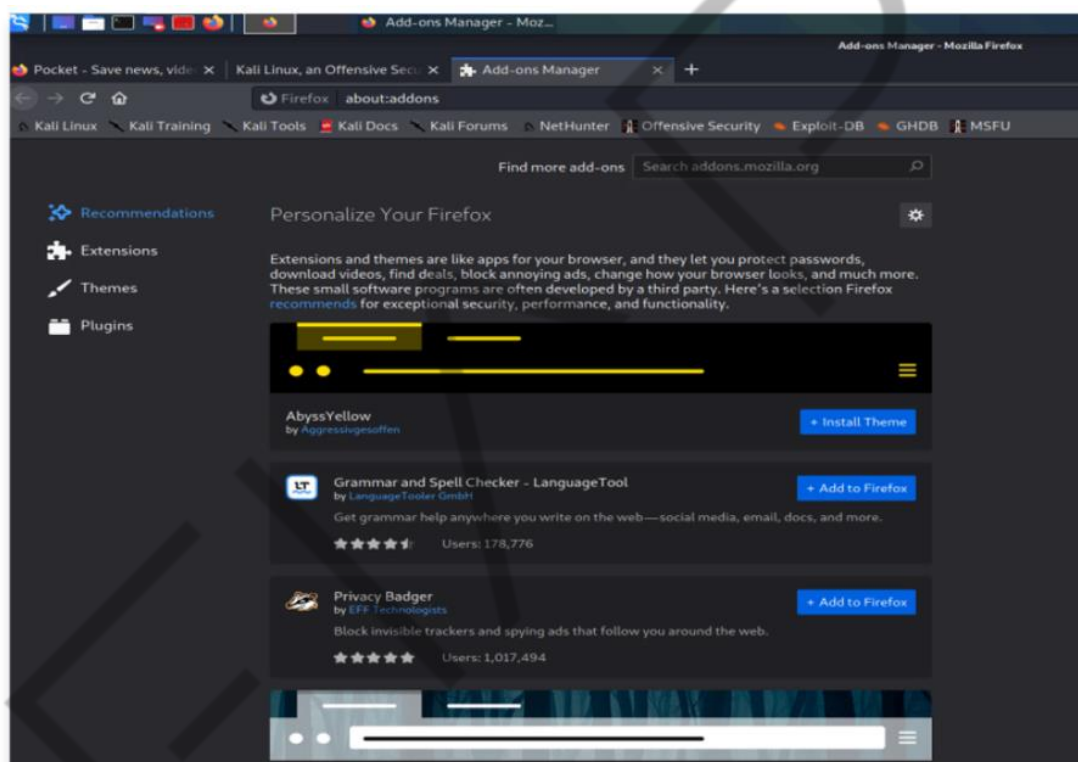


Figura 14 – Instalação FoxyProxy(1)
Fonte: Elaborado pelo autor (2021)

Ao realizar a pesquisa da extensão, inúmeras opções estarão disponíveis. Escolha a FoxyProxy Standard, conforme a Figura “Instalação FoxyProxy (2)”.

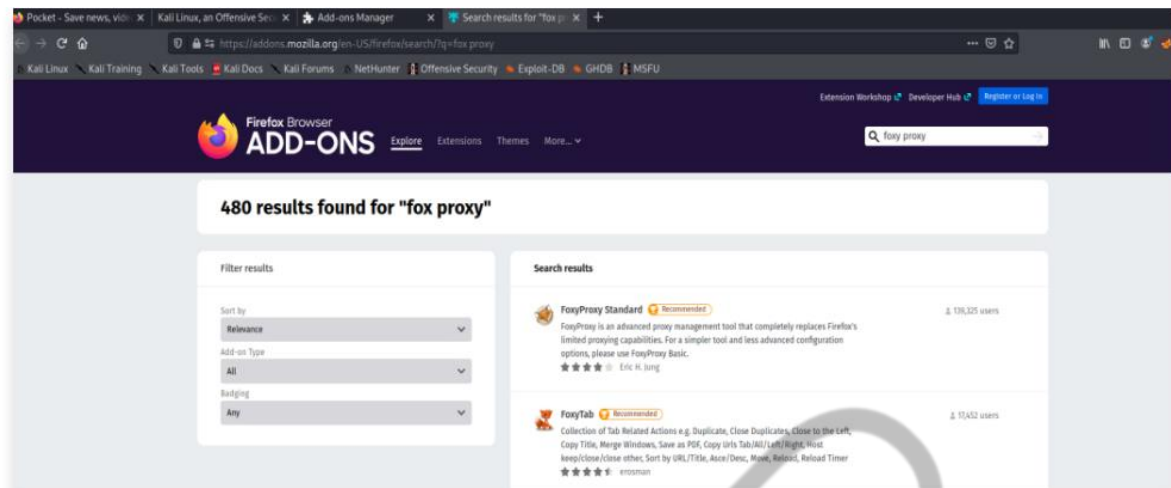


Figura 15 – Instalação FoxyProxy(2)
Fonte: Elaborado pelo autor (2021)

Clique na opção e, logo em seguida, no botão “Addto Firefox”, conforme a Figura “Instalação FoxyProxy (3)”.

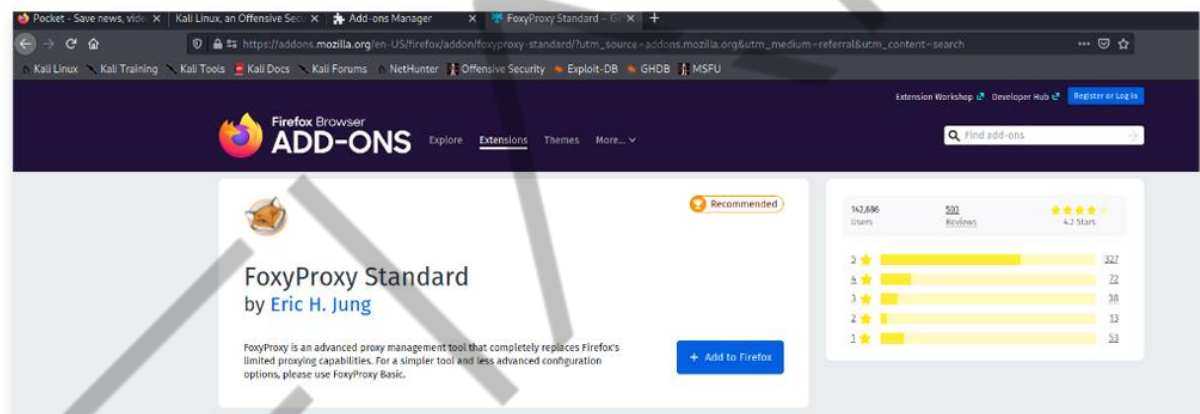


Figura 16 – Instalação FoxyProxy(3)
Fonte: Elaborado pelo autor (2021)

Após esse processo, a extensão ficará disponível na barra de navegação do Firefox, conforme a Figura “Instalação do FoxyProxy (4)”.

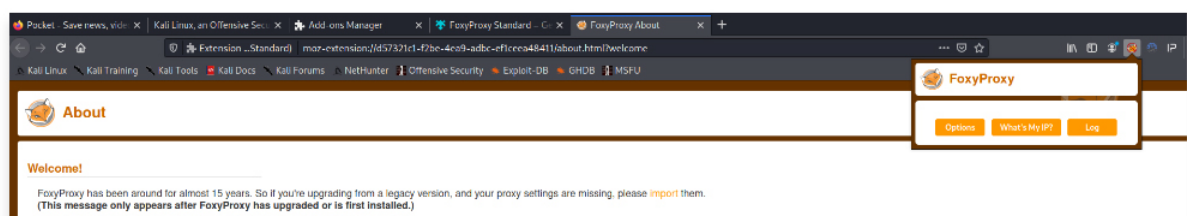


Figura 17 – Instalação FoxyProxy(4)
Fonte: Elaborado pelo autor (2021)

Para realização de sua configuração, clicamos no ícone do FoxyProxy e, logo em seguida, no botão “Options”, que irá retornar algumas opções, conforme a Figura “Instalação FoxyProxy (5)”.

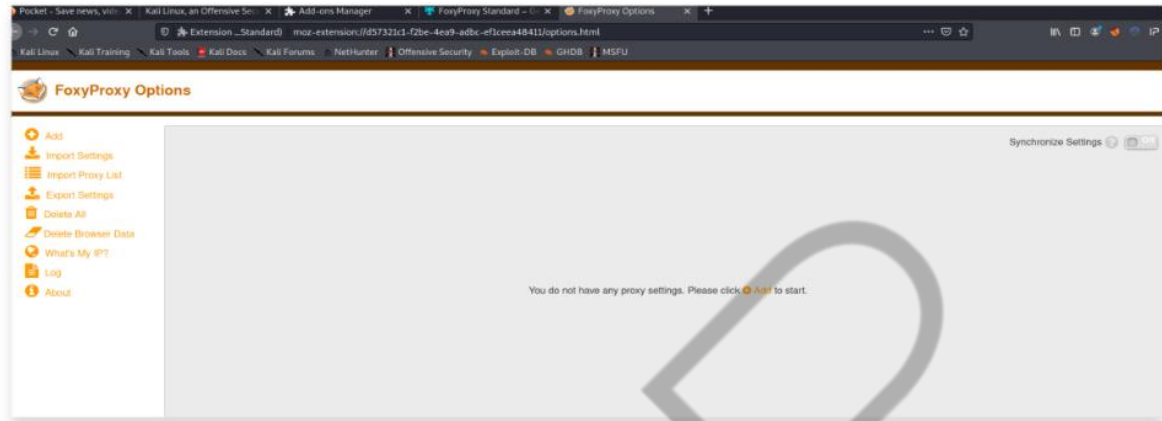


Figura 18 – Instalação FoxyProxy(5)
Fonte: Elaborado pelo autor (2021)

Clique no botão “Add” e procederemos à configuração do Proxy, que irá redirecionar o tráfego para o BurpSuite. Nessa configuração, definiremos o título de “BurpSuite”, IP address “127.0.0.1” e “porta 3128”. Clique em “Save” e sua configuração estará pronta para interceptar o tráfego do navegador, conforme a Figura “Instalação FoxyProxy (6)”.

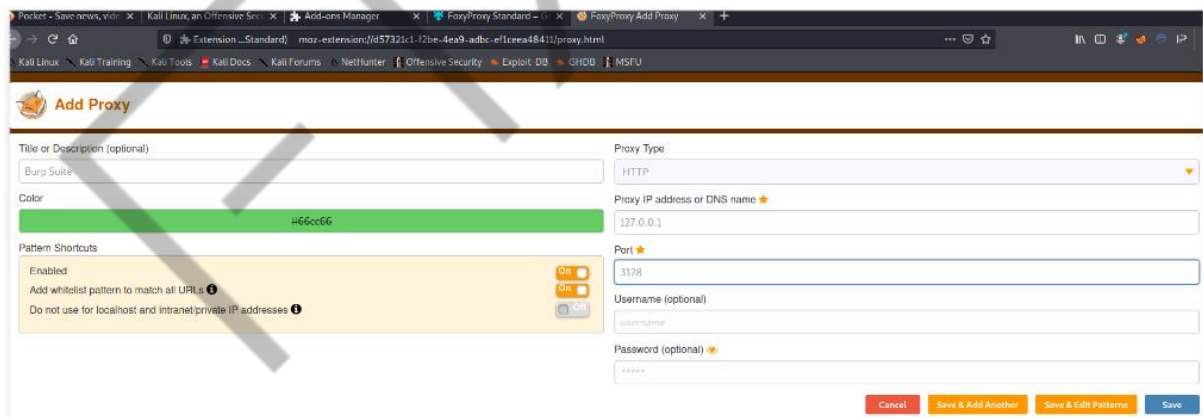


Figura 19 – Instalação FoxyProxy(6)
Fonte: Elaborado pelo autor (2021)

Ao clicar no botão do FoxyProxy no navegador, estará disponível a configuração do Proxy de redirecionamento de tráfego para o BurpSuite, conforme a Figura “Instalação do FoxyProxy (7)”.

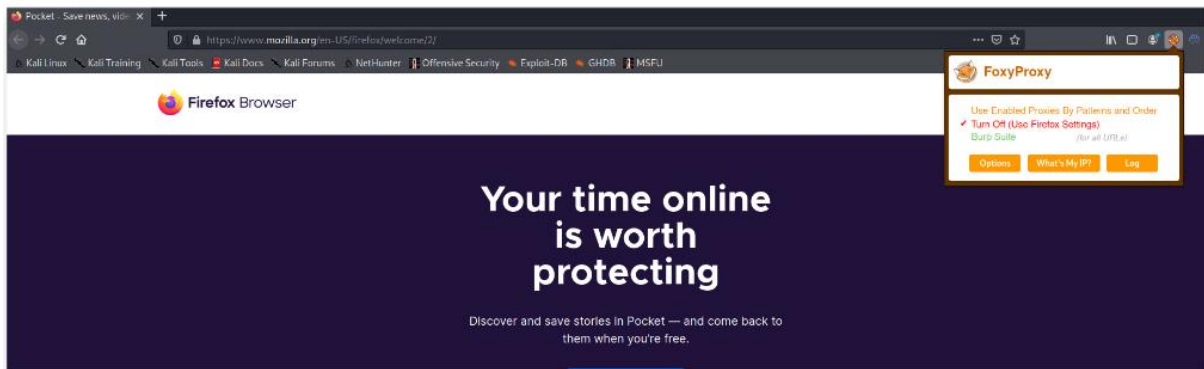


Figura 20 – Instalação FoxyProxy(7)
Fonte: Elaborado pelo autor (2021)

Essa extensão facilita a utilização e a configuração de um tunelamento proxy, redirecionando o tráfego do navegador web, para que ele seja analisado pelo BurpSuite.

Após os passos supracitados, realizamos a instalação do Google Chrome e da extensão cookie manager.

Para a instalação do navegador Google Chrome, realizamos o download do navegador no endereço: <https://www.google.com/intl/pt-BR/chrome/>. Basta clicar no ícone “**Fazer o download do Google Chrome**”, e ele será descarregado no Kali.

Após o download, basta seguir o Comando de Prompt “Instalação Google Chrome”, que ele realizará a instalação do navegador.

```
—(root👤kali)-[/home/jangow]
└─#
—(root👤kali)-[/home/jangow]
└─# cd Downloads

—(root👤kali)-[/home/jangow/Downloads]
└─# dpkg -i google-chrome-stable_current_amd64.deb
A seleccionar pacote anteriormente não seleccionado google-chrome-stable.
(Lendo banco de dados ... 264452 ficheiros e directórios atualmente instalados.)
A preparar para desempacotar google-chrome-stable_current_amd64.deb ...
A descompactar google-chrome-stable (89.0.4389.82-1) ...
Configurando google-chrome-stable (89.0.4389.82-1) ...
update-alternatives: a usar /usr/bin/google-chrome-stable para disponibilizar /usr/bin/x-
www-browser (x-www-browser) em modo auto
update-alternatives: a usar /usr/bin/google-chrome-stable para disponibilizar
/usr/bin/gnome-www-browser (gnome-www-browser) em modo auto
update-alternatives: a usar /usr/bin/google-chrome-stable para disponibilizar
/usr/bin/google-chrome (google-chrome) em modo auto
```

```
A processar 'triggers' para kali-menu (2020.4.0) ...  
A processar 'triggers' para desktop-file-utils (0.26-1) ...  
A processar 'triggers' para mime-support (3.64) ...  
A processar 'triggers' para man-db (2.9.3-2) ...
```

```
(root@kali)-[/home/jangow/Downloads]  
#
```

Comando de prompt 3 – Instalação Google Chrome
Fonte: Elaborado pelo autor (2021)

Para a instalação do complemento cookie manager, efetuamos sua busca na barra de pesquisa de complementos do Firefox, conforme a Figura “Instalação Cookie Manager (1)”.

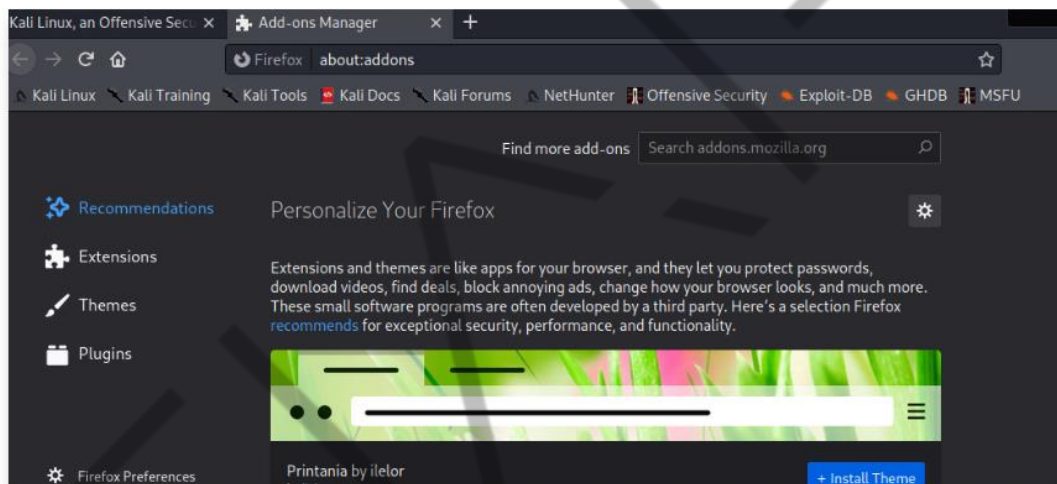


Figura 21 – Instalação Cookie Manager (1)
Fonte: Elaborado pelo autor (2021)

Escolhemos o primeiro da lista e clicamos em “Adicionar”, conforme a Figura “Instalação Cookie Manager (2)” e a Figura “Instalação do Cookie Manager (3)”.

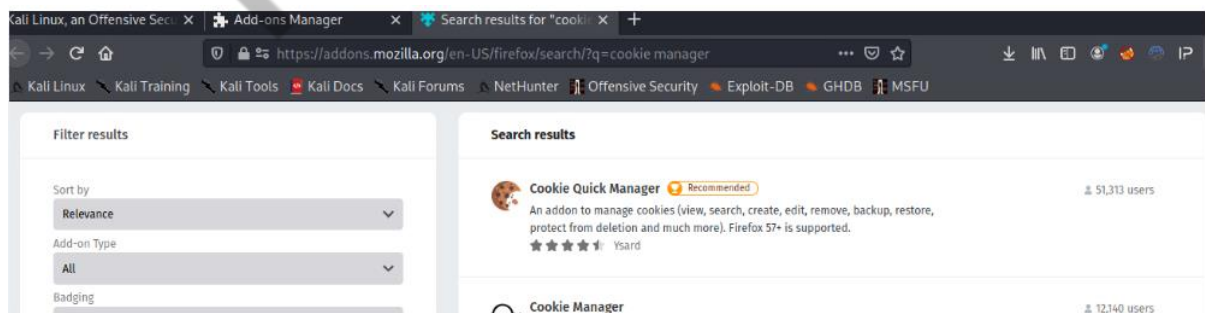


Figura 22 – Instalação Cookie Manager (2)
Fonte: Elaborado pelo autor (2021)

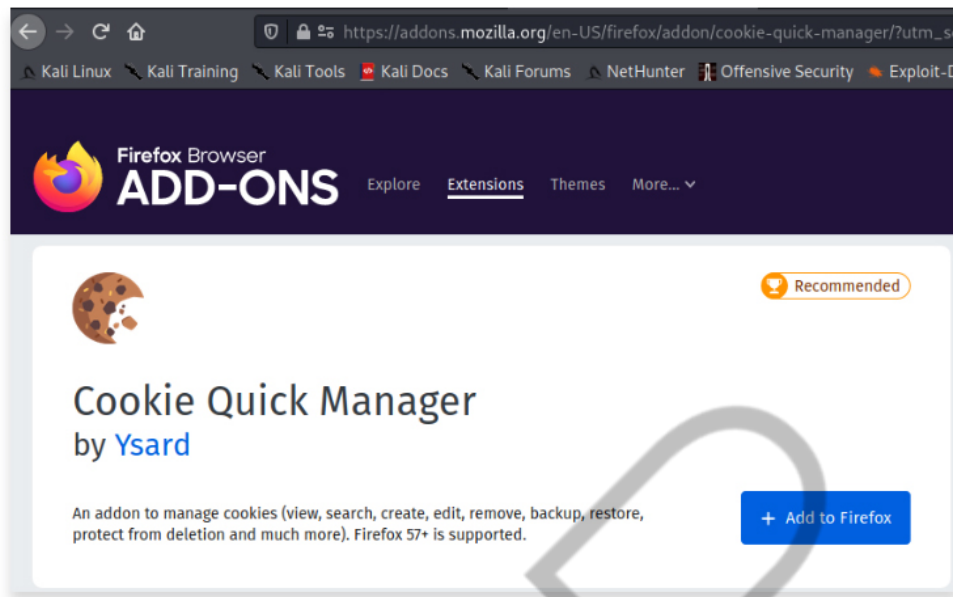


Figura 23 – Instalação Cookie Manager (3)
Fonte: Elaborado pelo autor (2021)

Após a instalação, o ícone do complemento ficará à disposição do usuário na barra de navegação, conforme a Figura “Instalação Cookie Manager (4)”.

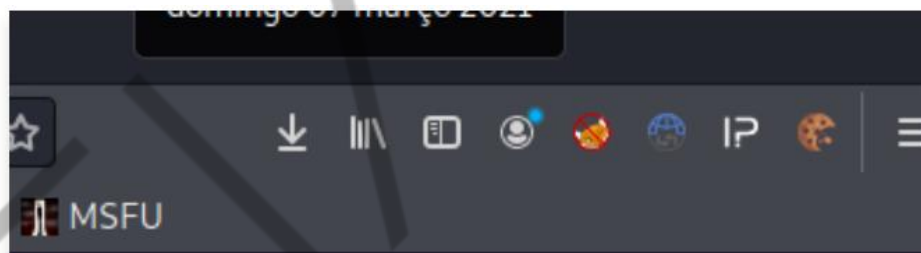


Figura 24 – Instalação Cookie Manager (4)
Fonte: Elaborado pelo autor (2021)

A mesma instalação deve ser realizada no navegador Google Chrome, seguindo o mesmo processo.

3 BURPSUITE

Quando tratamos sobre o Pentest Web, a ferramenta BurpSuite é um importante e essencial atributo para o processo de manipulação e exploração Web.

Por meio dela, podemos interceptar tráfegos Web, manipular requisições, interceptar respostas, executar ataques de força bruta e, principalmente, inspecionar comportamentos, objetivando a identificação de vulnerabilidades e potenciais falhas de segurança.

A ferramenta possui diversos tipos de licenças, possibilitando muitas opções de interatividade e processos automatizados. Porém, nossa utilização abordará as etapas gratuitas, buscando a realização de atividades manuais, contudo, muito importantes e eficazes.

Para conhecer mais sobre as diferentes versões da ferramenta, basta acessar o seguinte endereço: <https://portswigger.net/burp>.

As interfaces de utilização da ferramenta dentro de nosso escopo são muito importantes para as ações de Pentester. São os módulos Proxy, Intruder e Repeater.

Neste tópico, abordaremos apenas uma breve descrição e integração para seu emprego e os campos mais utilizados.

Iniciando nossa integração, acesse o menu do seu Kali Linux, digite Burp e clique no ícone da ferramenta para sua inicialização, conforme as Figuras “BurpSuite (1)”, “BurpSuite (2)” e “BurpSuite (3)”.

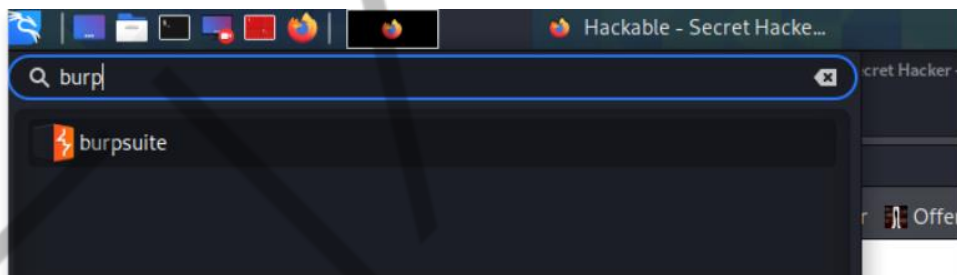


Figura 25 –BurpSuite(1)
Fonte: Elaborado pelo autor (2021)

Após a inicialização, selecione a configuração do Burp, na extensão do FoxProxy no navegador Firefox.



Figura 26 –BurpSuite(2)
Fonte: Elaborado pelo autor (2021)

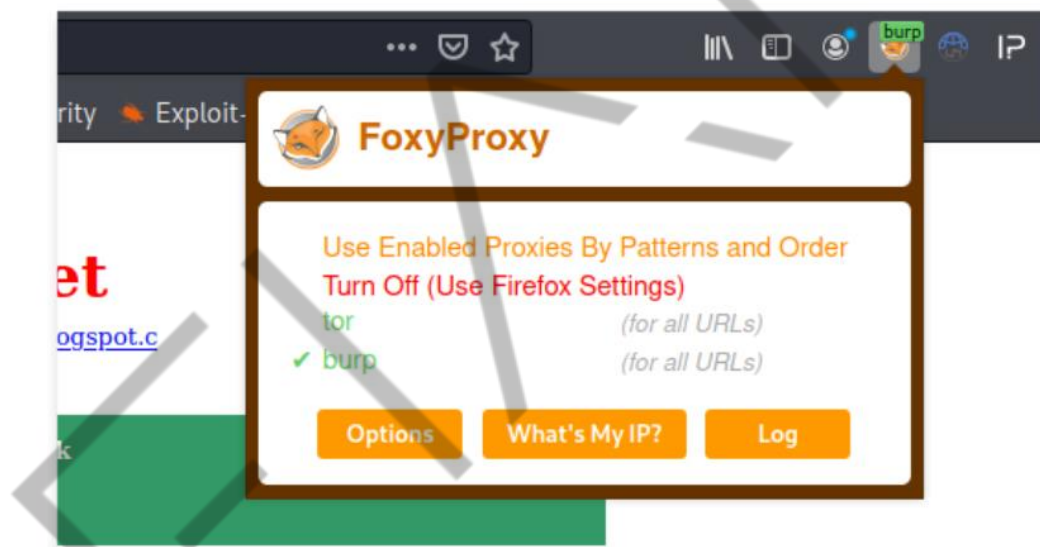


Figura 27 –BurpSuite(3)
Fonte: Elaborado pelo autor (2021)

Com a ferramenta iniciada, conforme a Figura “BurpSuite (4)”, o processo de interceptação de tráfego foi inicializado.

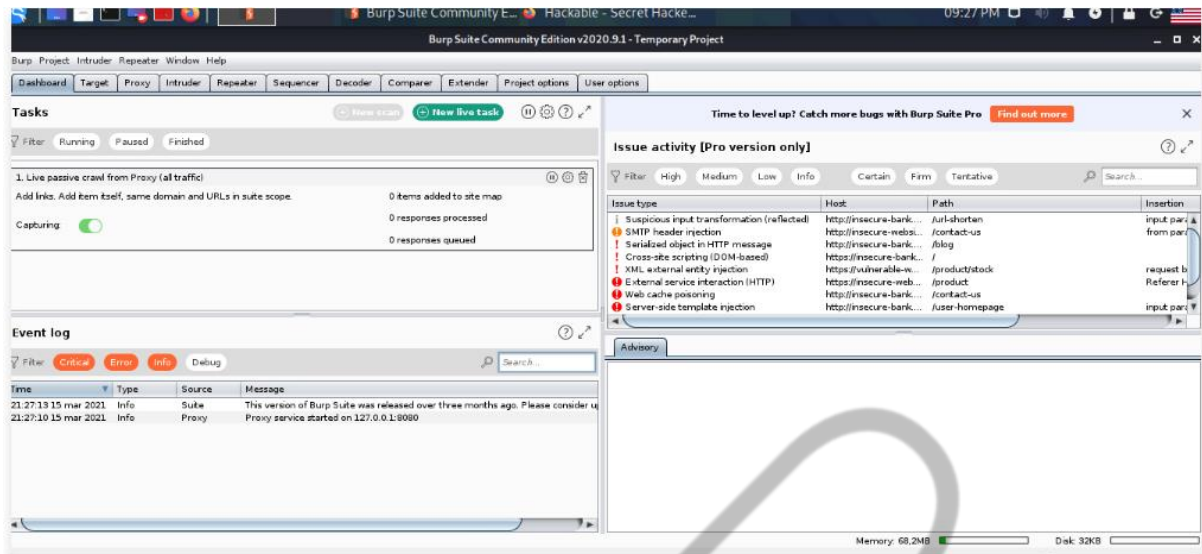


Figura 28 –BurpSuite(4)
Fonte: Elaborado pelo autor (2021)

Dentre as opções desta poderosa ferramenta, iniciamos nossa integração no módulo proxy. Para essa ação, acessamos o endereço: <http://<IP MAQUINA ALVO>/002/index.php?page=login.php>.

Basicamente, o módulo de Proxy, conforme a Figura “BurpSuite (5)”, realiza a captura do tráfego do navegador, redirecionando seus dados para análise no BurpSuite.

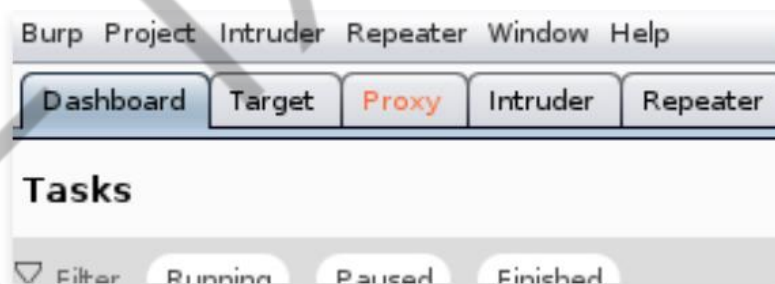


Figura 29 –BurpSuite(5)
Fonte: Elaborado pelo autor (2021)

A interceptação do tráfego é instantânea. Com o FoxyProxy ativado no Burp, qualquer navegação realizada é automaticamente redirecionada, conforme as Figuras “BurpSuite (6)” e “BurpSuite (7)”.

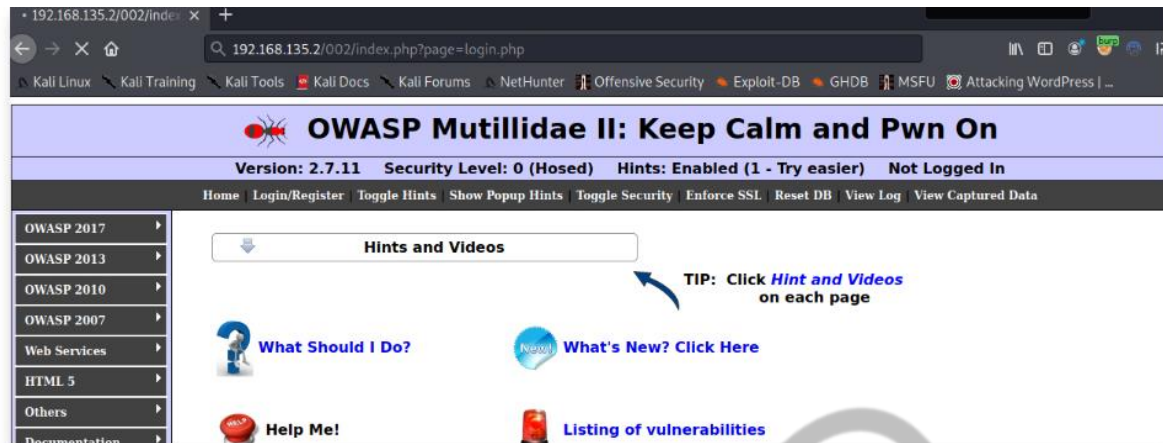


Figura 30 –BurpSuite(6)
Fonte: Elaborado pelo autor (2021)

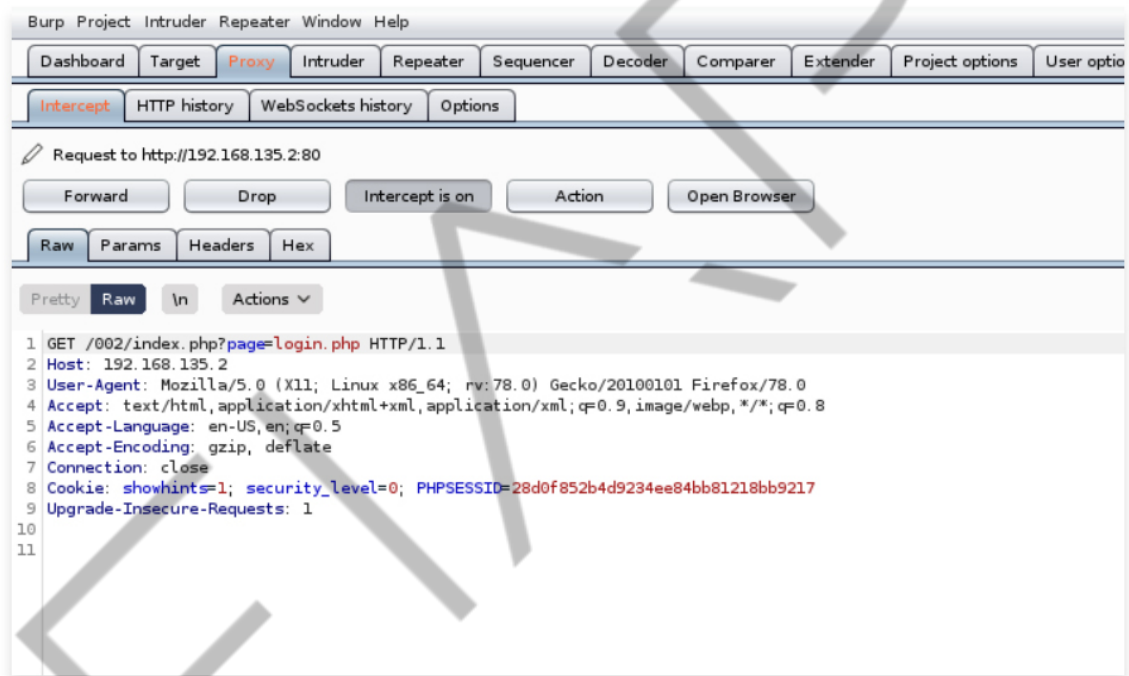


Figura 31 –BurpSuite(7)
Fonte: Elaborado pelo autor (2021)

No módulo Repeater do BurpSuite, realizamos as interações do serviço Web, manipulando requisições GET e POST e, propiciando análises de resposta do serviço potencialmente vulnerável.

Para esta utilização, basta clicarmos no botão Action e enviar a captura para o módulo de Repeater, no qual ela poderá ser tratada, conforme as Figuras “BurpSuite (8)”, “BurpSuite (9)” e “BurpSuite (10)”.

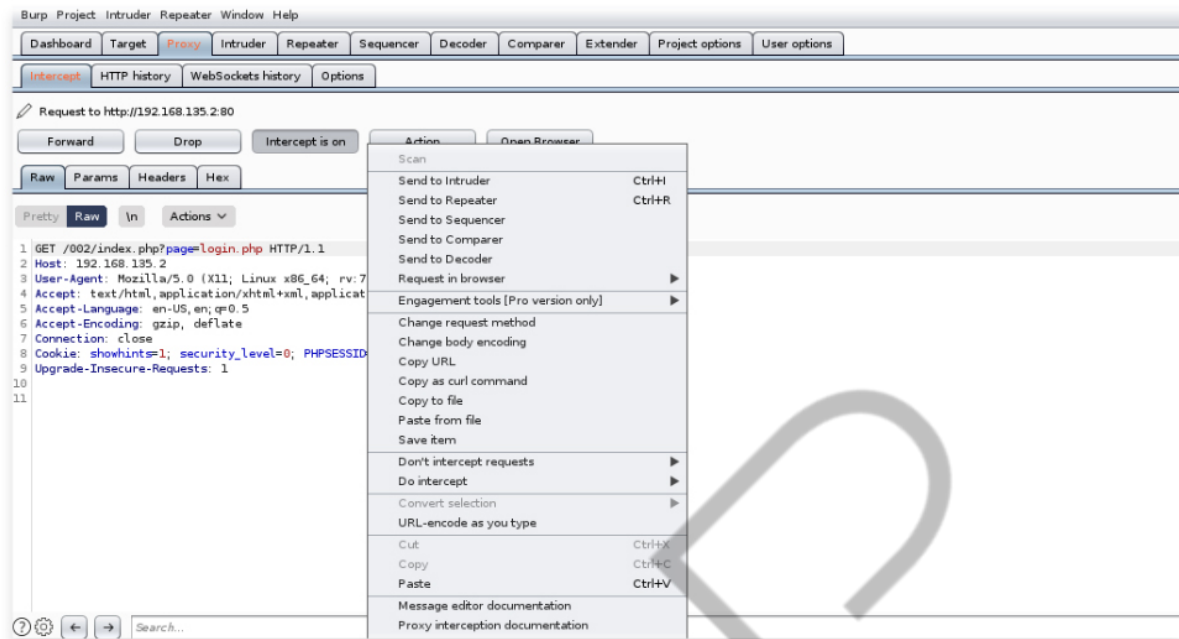


Figura 32 –BurpSuite(8)
Fonte: Elaborado pelo autor (2021)

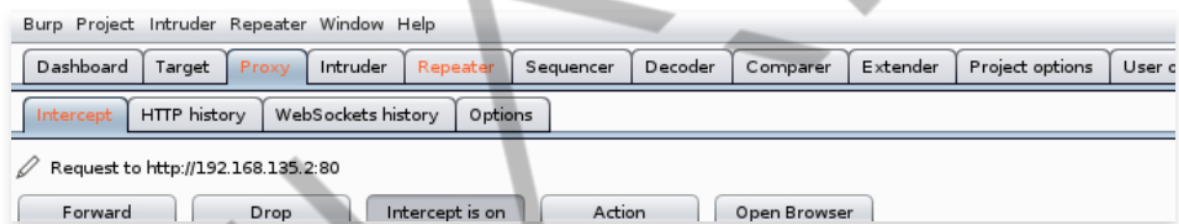


Figura 33 –BurpSuite(9)
Fonte: Elaborado pelo autor (2021)

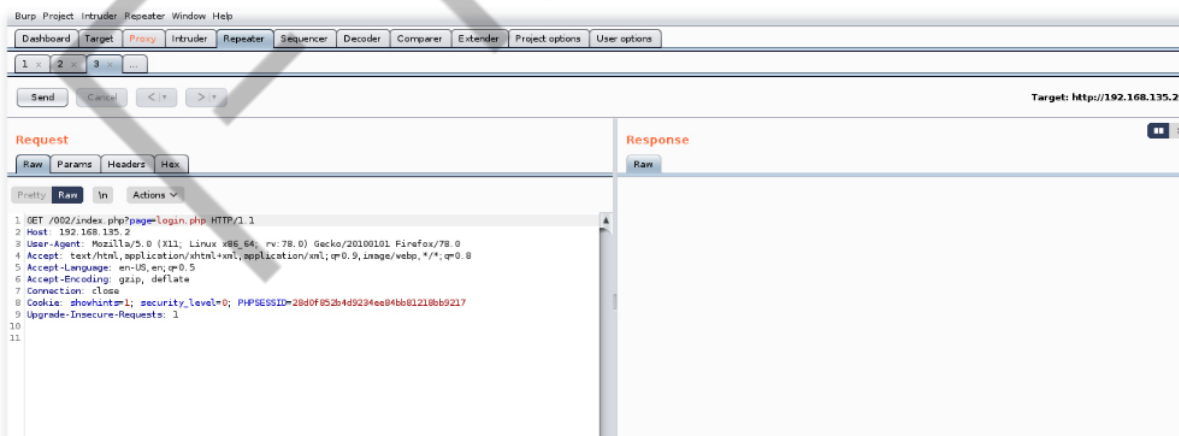


Figura 34 –BurpSuite (10)
Fonte: Elaborado pelo autor (2021)

Para enviar a requisição manipulada, basta clicar no botão “Send” e a resposta aparecerá na tela ao lado, conforme a Figura “BurpSuite (11)”.

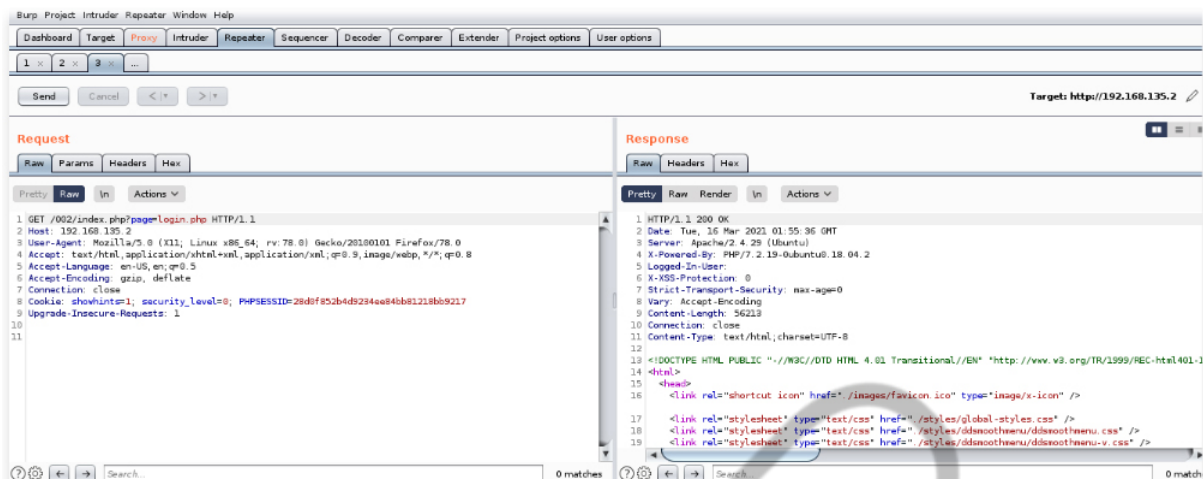


Figura 35 –BurpSuite(11)
Fonte: Elaborado pelo autor (2021)

Um ponto importante é que a requisição Web em nosso navegador continua pausada no ponto de nossa captura, porém, na ferramenta, obtemos respostas, manipulando respostas, conforme a Figura “BurpSuite (12)”.

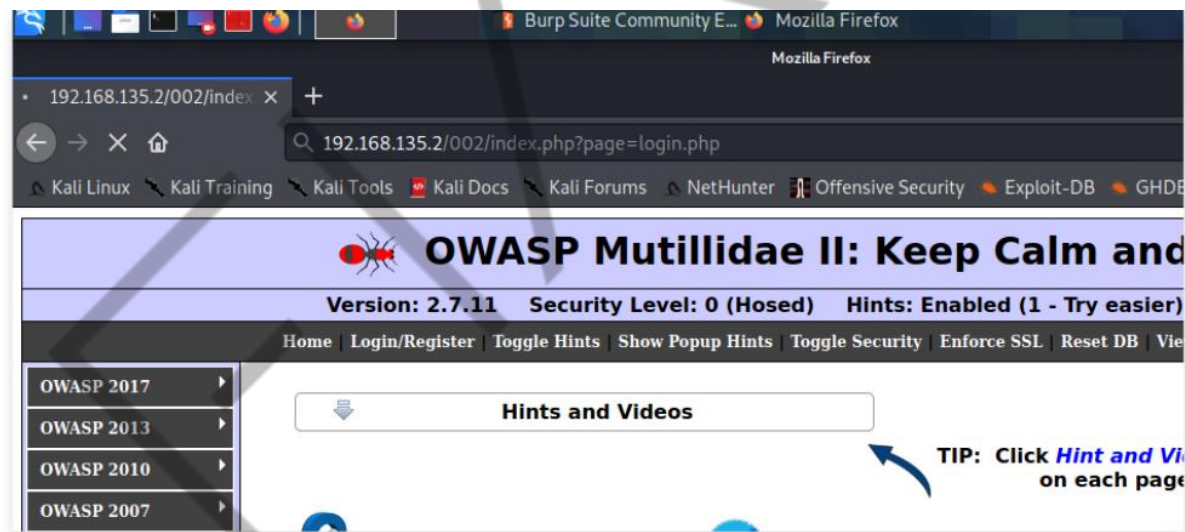


Figura 36 –BurpSuite(12)
Fonte: Elaborado pelo autor (2021)

O módulo seguinte é o Intruder, no qual podemos realizar ataques de força bruta, em requisições Web. Para sua utilização, semelhante ao evento anterior, enviamos a requisição capturada pelo proxy para o módulo Intruder, conforme a Figura “BurpSuite (13)”.

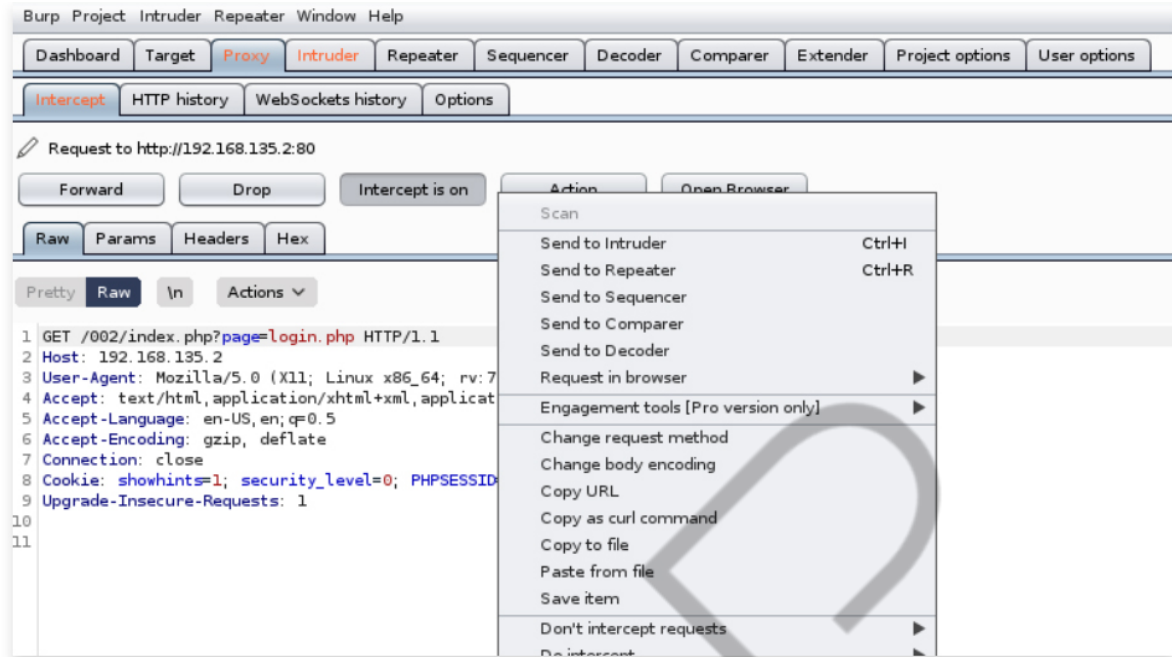


Figura 37 –BurpSuite(13)
Fonte: Elaborado pelo autor (2021)

Essa exploração pode ser realizada de maneira simples, bastando selecionar os campos que se deseja testar na aba “Positions”, conforme a Figura “BurpSuite (14)”. Atente-se que os campos selecionados para teste se encontram em coloração diferente.

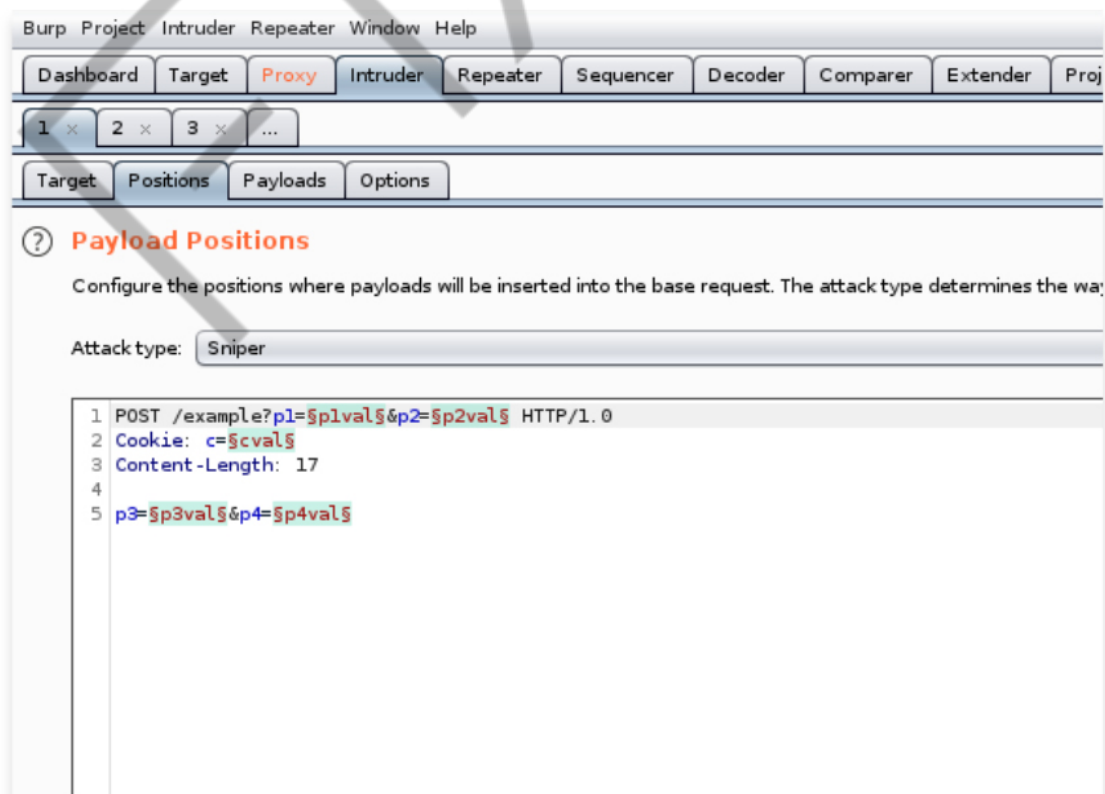


Figura 38 –BurpSuite(14)
Fonte: Elaborado pelo autor (2021)

Para escolhermos a lista de teste de parâmetros, utilizamos a aba “Payloads”, a qual selecionamos e utilizamos para a realização do ataque, conforme a Figura “BurpSuite (15)”.

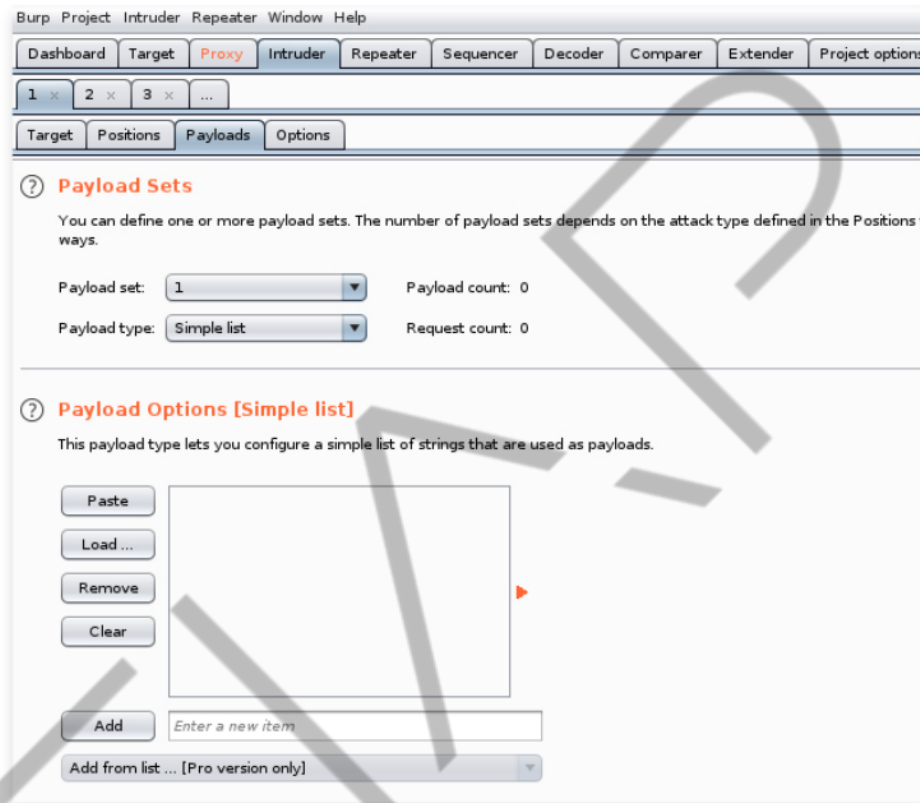


Figura 39 –BurpSuite(15)
Fonte: Elaborado pelo autor (2021)

4 IDENTIFICANDO ARQUIVOS E DIRETÓRIOS

Nesta etapa de execução do Pentest, o profissional deve atentar-se à existência de diretórios e arquivos que possam estar escondidos ou indisponíveis para acesso direto pelo usuário.

Como primeiro passo, precisamos identificar o endereço IP adotado para nossa máquina virtual de testes, Pentest Web. Para sua obtenção, executamos o Comando de prompt “Identificando arquivos e diretórios (1)”, observando seu retorno na Figura “Identificando arquivos e diretórios (1)”.


```

—(jangow@kali)-[~]
└─$ sudonetdiscover -r 192.168.135.0/24

```

Comando de prompt 4 – Identificando Arquivos e Diretórios (1)
 Fonte: Elaborado pelo autor (2021)

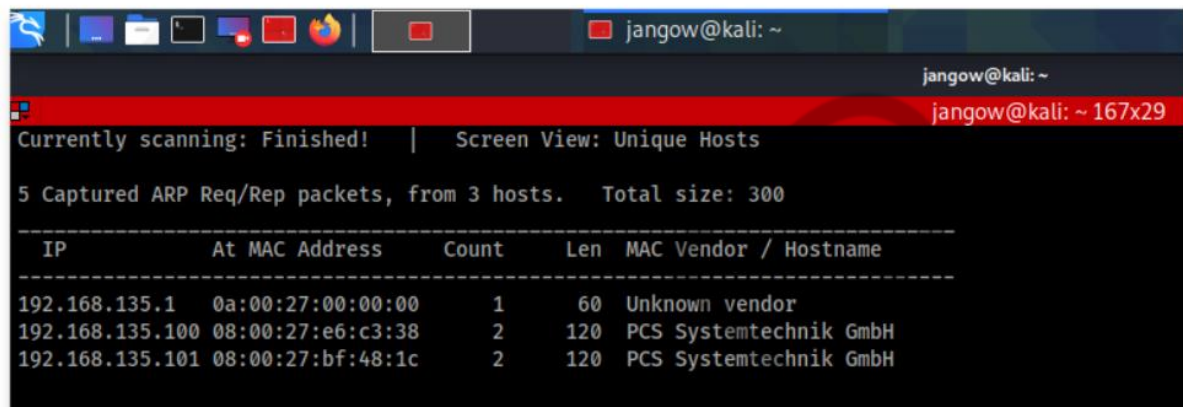


Figura 40 – Identificando Arquivos e Diretórios (1)
 Fonte: Elaborado pelo autor (2021)

Percebemos que o IP de nossa máquina-alvo corresponde ao 192.168.135.101.

A identificação dos serviços web disponíveis no host pode ser realizada por meio do mapeamento do Nmap, ou de outra ferramenta de sua preferência, conforme os Comandos de prompt “Identificando arquivos e diretórios (2)” e “Identificando arquivos e diretórios (3)”.

```

—(jangow@kali)-[~]
└─$ sudonmap -sS -sV -sC -p 192.168.135.101 --min-rate=10000

```

Comando de prompt 5 – Identificando Arquivos e Diretórios (2)
 Fonte: Elaborado pelo autor (2021)

```

mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is
disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.135.101
Host is up (0.19s latency).
Not shown: 65527 closed ports
PORT      STATE SERVICE  VERSION
22/tcpopen ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 03:2d:4a:3d:4f:36:ae:df:e7:f8:9e:9e:06:c6:50:4b (RSA)

```



```
| 256 bb:cf:30:c4:f1:83:4d:c8:5a:cd:8f:30:83:c5:6e:18 (ECDSA)
|_ 256 8b:3f:87:e9:fb:24:e6:7d:a4:36:71:3e:dd:dd:49:45 (ED25519)
80/tcpopen http Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Hackable - Secret Hacker
139/tcp opennetbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp open https
| fingerprint-strings:
|   GenericLines, SSLSessionReq, SSLv23SessionReq, TLSSessionReq:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
|   GetRequest:
|     HTTP/1.0 200 OK
|     Content-Type: text/html; charset=UTF-8
|     Set-Cookie: lang=en-US; Path=/; Max-Age=2147483647
|     Set-Cookie: i_like_gitea=decf9bfeb085eb22; Path=/; HttpOnly
|     Set-Cookie: _csrf=Ep7wd7RM-
PHCuomyEZvMAQDbG5o6MTYxNDUzOTMwMDkzNDkzNDA2Mg%3D%3D; Path=/;
Expires=Mon, 01 Mar 2021 19:08:20 GMT; HttpOnly
|     X-Frame-Options: SAMEORIGIN
|     Date: Sun, 28 Feb 2021 19:08:20 GMT
|     <!DOCTYPE html>
|     <html lang="en-US">
|     <head data-suburl="">
|     <meta charset="utf-8">
|     <meta name="viewport" content="width=device-width, initial-scale=1">
|     <meta http-equiv="x-ua-compatible" content="ie=edge">
|     <title> Hackable - Secret Hacker</title>
|     <link rel="manifest" href="/manifest.json" crossorigin="use-credentials">
|     <script>
|     ('serviceWorker' in navigator) {
|     window.addEventListener('load', function() {
|     navigator.serviceWorker.register('/serviceworker.js').then(function(registration)
|     {
|   HTTPOptions:
|     HTTP/1.0 404 Not Found
|     Content-Type: text/html; charset=UTF-8
|     Set-Cookie: lang=en-US; Path=/; Max-Age=2147483647
|     Set-Cookie: i_like_gitea=c9ce29ca06bb577f; Path=/; HttpOnly
|     Set-Cookie:
|_csrf=110zHjBkOorYkUcmeBaNvz1mADY6MTYxNDUzOTMwMDk1MDE0MzY2Mg%
3D%3D; Path=/; Expires=Mon, 01 Mar 2021 19:08:20 GMT; HttpOnly
|     X-Frame-Options: SAMEORIGIN
|     Date: Sun, 28 Feb 2021 19:08:20 GMT
|     <!DOCTYPE html>
|     <html lang="en-US">
|     <head data-suburl="">
```

```

| <meta charset="utf-8">
| <meta name="viewport" content="width=device-width, initial-scale=1">
| <meta http-equiv="x-ua-compatible" content="ie=edge">
| <title>Page Not Found - Hackable - Secret Hacker</title>
| <link rel="manifest" href="/manifest.json" crossorigin="use-credentials">
| <script>
| ('serviceWorker' in navigator) {
|   window.addEventListener('load', function() {
|     navigator.serviceWorker.register('/serviceworker.js').then(function(reg
|_ http-title: Hackable - Secret Hacker
445/tcp opennetbios-ssn Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
5001/tcpopen java-object Java Object Serialization
8080/tcpopen http-proxy
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 404
|     Content-Type: text/html; charset=utf-8
|     Content-Language: en
|     Content-Length: 1083
|     Date: Sun, 28 Feb 2021 19:08:11 GMT
|     Connection: close
|     <!doctype html><html lang="en"><head><title>HTTP Status 404
|       Found</title><style type="text/css">h1 {font-family:Tahoma,Arial,sans-
| serif;color:white;background-color:#525D76;font-size:22px;} h2 {font-
| family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-
| size:16px;} h3 {font-family:Tahoma,Arial,sans-serif;color:white;background-
| color:#525D76;font-size:14px;} body {font-family:Tahoma,Arial,sans-
| serif;color:black;background-color:white;} b {font-family:Tahoma,Arial,sans-
| serif;color:white;background-color:#525D76;} p {font-family:Tahoma,Arial,sans-
| serif;background:white;color:black;font-size:12px;} a {color:black;} a.name
| {color:black;} .line {height:1px;background-
| color:#525D76;border:none;}</style></head><body>
|   HTTPOptions:
|     HTTP/1.1 200
|     Allow: OPTIONS, GET, HEAD, POST
|     Content-Length: 0
|     Date: Sun, 28 Feb 2021 19:08:11 GMT
|     Connection: close
|   RTSPRequest:
|     HTTP/1.1 505
|     Content-Type: text/html; charset=utf-8
|     Content-Language: en
|     Content-Length: 2182
|     Date: Sun, 28 Feb 2021 19:08:11 GMT
|     <!doctype html><html lang="en"><head><title>HTTP Status 505
|_   HTTP Version Not Supported</title><style type="text/css">h1 {font-
| family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-
| size:22px;} h2 {font-family:Tahoma,Arial,sans-serif;color:white;background-
| color:#525D76;font-size:16px;} h3 {font-family:Tahoma,Arial,sans-

```

[illegible]

[illegible]

```
SF:hite;background-color:#525D76;font-size:16px;}\x20h3\x20{font-family:Ta
SF:homa,Arial,sans-serif;color:white;background-color:#525D76;font-size:14
SF:px;}\x20body\x20{font-family:Tahoma,Arial,sans-serif;color:black;backgr
SF:ound-color:white;}\x20b\x20{font-family:Tahoma,Arial,sans-serif;color:w
SF:hite;background-color:#525D76;}\x20p\x20{font-family:Tahoma,Arial,sans-
SF:serif;background:white;color:black;font-size:12px;}\x20a\x20{color:blac
SF:k;}\x20a\.name\x20{color:black;}\x20\.line\x20{height:1px;background-co
SF:lor:#525D76;border:none;}</style></head><body><h">
MAC Address: 08:00:27:BF:48:1C (Oracle VirtualBox virtual NIC)
Service Info: Host: HACKABLE; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Host script results:

```
|_ clock-skew: mean: -1s, deviation: 0s, median: -2s
|_ nbstat: NetBIOS name: HACKABLE, NetBIOS user: <unknown>, NetBIOS MAC:
<unknown> (unknown)
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
|   Computer name: hackable
|   NetBIOS computer name: HACKABLE\x00
|   Domain name: \x00
|   FQDN: hackable
|_ System time: 2021-02-28T19:09:37+00:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   2.02:
|_     Message signing enabled but not required
| smb2-time:
|   date: 2021-02-28T19:09:36
|_ start_date: N/A
```

Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 142.00 seconds

Comando de prompt 6 – Identificando Arquivos e Diretórios (3)
Fonte: Elaborado pelo autor (2021)

Conforme o resultado mostrado na saída do Nmap, observamos a existência das portas 80 e 8080, com o serviço Web rodando.

A partir desse dado, procedemos à identificação dos diretórios e arquivos possivelmente ocultos ao usuário.

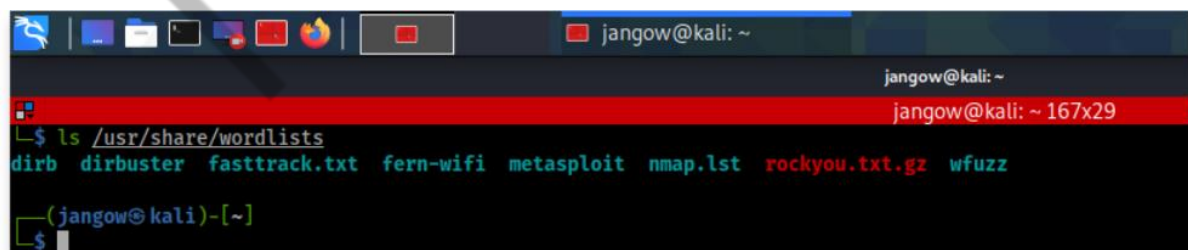
A identificação de diretórios possui uma grande importância na verificação e estudo de vulnerabilidades Web. O objetivo principal na atuação do Pentester é identificar possibilidades de falhas de segurança presentes nas aplicações disponíveis. Por meio dessas vulnerabilidades, incidentes diversos podem ocorrer, desde o vazamento de dados, a utilização indevida de servidores corporativos e o comprometimento de infraestruturas.

Assim, dando continuidade ao processo de identificação de diretórios e arquivos que venham, de alguma forma, proporcionar comprometimento de segurança por meio de uma configuração indevida ou falha de algum *framework*. Para esse processo, existem inúmeras ferramentas que podem ser utilizadas, entre as principais, utilizaremos o Dirb, o Gobuster e o Nikto.

4.1 Dirb

O Dirb é uma ferramenta de terminal muito utilizada para levantamento de diretórios de serviços web.

Sua utilização baseia-se em um comando simples combinado a parâmetros e uma boa *wordlist* de identificação de diretórios Web. Por padrão, a distribuição Kali Linux possui excelentes *wordlists* para este processo. Geralmente, estão localizadas no diretório **/usr/share/wordlists**, a mais comum é a *big.txt* e fica no diretório **/usr/share/wordlists/dirb**, conforme as Figuras “Identificando arquivos e diretórios (2)” e “Identificando arquivos e diretórios (3)”.



```
jangow@kali: ~  
jangow@kali: ~ 167x29  
$ ls /usr/share/wordlists  
dirb  dirbuster  fasttrack.txt  fern-wifi  metasploit  nmap.lst  rockyou.txt.gz  wfuzz  
(jangow@kali)-[~]  
$
```

Figura 41 – Identificando Arquivos e Diretórios (2)
Fonte: Elaborado pelo autor (2021)

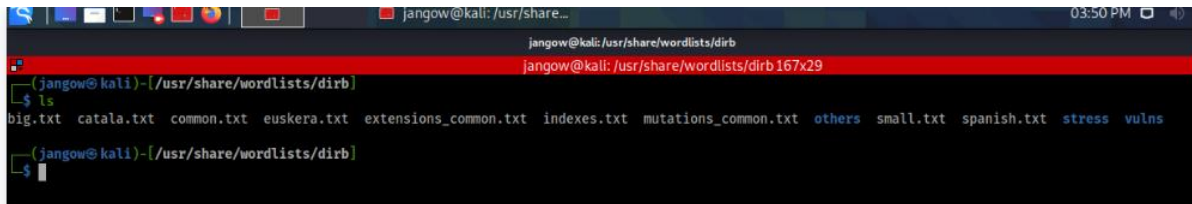


Figura 42 –Identificando Arquivos e Diretórios (3)

Fonte: Elaborado pelo autor (2021)

A compilação básica do comando do Dirb segue, conforme Comando de Prompt “Identificando Arquivos e Diretórios (4)” e seu resultado pode ser observado no Comando de prompt “Identificando Arquivos e Diretórios (5)”.

```
(janguow@kali)-[/usr/share/wordlists/dirb]  
└─$ dirb http://192.168.135.101 /usr/share/wordlists/dirb/big.txt
```

Comando de prompt 7 – Identificando Arquivos e Diretórios (4)

Fonte: Elaborado pelo autor (2021)

```
DIRB v2.22  
By The Dark Raver  
-----  
  
START_TIME: Sun Feb 28 15:54:24 2021  
URL_BASE: http://192.168.135.101/  
WORDLIST_FILES: /usr/share/wordlists/dirb/big.txt  
  
-----  
  
GENERATED WORDS: 20458  
  
---- Scanning URL: http://192.168.135.101/ ----  
==> DIRECTORY: http://192.168.135.101/001/  
  
==> DIRECTORY: http://192.168.135.101/002/  
  
==> DIRECTORY: http://192.168.135.101/007/  
  
==> DIRECTORY: http://192.168.135.101/images/  
  
==> DIRECTORY: http://192.168.135.101/javascript/  
  
==> DIRECTORY: http://192.168.135.101/phpmyadmin/  
  
+ http://192.168.135.101/server-status (CODE:403|SIZE:280)
```

```
==> DIRECTORY: http://192.168.135.101/test/

---- Entering directory: http://192.168.135.101/001/ ----
==> DIRECTORY: http://192.168.135.101/001/config/

==> DIRECTORY: http://192.168.135.101/001/docs/

==> DIRECTORY: http://192.168.135.101/001/external/

+ http://192.168.135.101/001/favicon.ico (CODE:200|SIZE:1406)
+ http://192.168.135.101/001/robots.txt (CODE:200|SIZE:26)

---- Entering directory: http://192.168.135.101/002/ ----
==> DIRECTORY: http://192.168.135.101/002/ajax/

==> DIRECTORY: http://192.168.135.101/002/classes/

==> DIRECTORY: http://192.168.135.101/002/data/

==> DIRECTORY: http://192.168.135.101/002/documentation/

==> DIRECTORY: http://192.168.135.101/002/images/

==> DIRECTORY: http://192.168.135.101/002/includes/

==> DIRECTORY: http://192.168.135.101/002/javascript/

==> DIRECTORY: http://192.168.135.101/002/passwords/

==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/

+ http://192.168.135.101/002/robots.txt (CODE:200|SIZE:190)

==> DIRECTORY: http://192.168.135.101/002/styles/

==> DIRECTORY: http://192.168.135.101/002/test/

==> DIRECTORY: http://192.168.135.101/002/webservices/

---- Entering directory: http://192.168.135.101/007/ ----
==> DIRECTORY: http://192.168.135.101/007/images/

---- Entering directory: http://192.168.135.101/images/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

```
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/javascript/ ----
==> DIRECTORY: http://192.168.135.101/javascript/async/

==> DIRECTORY: http://192.168.135.101/javascript/events/

==> DIRECTORY: http://192.168.135.101/javascript/jquery/

==> DIRECTORY: http://192.168.135.101/javascript/util/

---- Entering directory: http://192.168.135.101/phpmyadmin/ ----
==> DIRECTORY: http://192.168.135.101/phpmyadmin/doc/

+ http://192.168.135.101/phpmyadmin/favicon.ico (CODE:200|SIZE:22486)

==> DIRECTORY: http://192.168.135.101/phpmyadmin/js/

+ http://192.168.135.101/phpmyadmin/libraries (CODE:403|SIZE:280)

==> DIRECTORY: http://192.168.135.101/phpmyadmin/locale/

+ http://192.168.135.101/phpmyadmin/setup (CODE:401|SIZE:462)

==> DIRECTORY: http://192.168.135.101/phpmyadmin/sql/

+ http://192.168.135.101/phpmyadmin/templates (CODE:403|SIZE:280)

==> DIRECTORY: http://192.168.135.101/phpmyadmin/themes/

---- Entering directory: http://192.168.135.101/test/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/001/config/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/001/docs/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/001/external/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/ajax/ ----
```

```
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/classes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/data/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/documentation/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/images/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/includes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/javascript/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/passwords/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/phpmyadmin/ ----
+ http://192.168.135.101/002/phpmyadmin/ChangeLog (CODE:200|SIZE:27794)

+ http://192.168.135.101/002/phpmyadmin/LICENSE (CODE:200|SIZE:18011)
+ http://192.168.135.101/002/phpmyadmin/README (CODE:200|SIZE:2101)
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/examples/
+ http://192.168.135.101/002/phpmyadmin/favicon.ico (CODE:200|SIZE:18902)
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/js/
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/libraries/
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/locale/
+ http://192.168.135.101/002/phpmyadmin/robots.txt (CODE:200|SIZE:26)
```

```
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/setup/
==> DIRECTORY: http://192.168.135.101/002/phpmyadmin/themes/

---- Entering directory: http://192.168.135.101/002/styles/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/test/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/002/webservices/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/007/images/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.135.101/javascript/async/ ----
+ http://192.168.135.101/javascript/async/async (CODE:200|SIZE:32659)

---- Entering directory: http://192.168.135.101/javascript/events/ ----
+ http://192.168.135.101/javascript/events/events (CODE:200|SIZE:8251)

---- Entering directory: http://192.168.135.101/javascript/jquery/ ----
+ http://192.168.135.101/javascript/jquery/jquery (CODE:200|SIZE:268026)

---- Entering directory: http://192.168.135.101/javascript/util/ ----
^C> Testing: http://192.168.135.101/javascript/util/pub

└─(jangow⊕kali)-[/usr/share/wordlists/dirb]
└─$
```

Comando de prompt 8 – Identificando Arquivos e Diretórios (5)
Fonte: Elaborado pelo autor (2021)

Podemos observar o comando Dirb, seguido do endereço do host web e a *wordlist* adotada. Um detalhe muito importante a ser percebido, por padrão, quando omitido, o Dirb adota a porta 80. Caso tenhamos interesse em realizar um levantamento em outra porta web existente, precisamos inserir a porta logo após o

endereço do host, conforme Comando de Prompt “Identificando Arquivos e Diretórios (6)”.

```
—(jangow@kali)-[/usr/share/wordlists/dirb]  
└─$ dirb http://192.168.135.101:8080 /usr/share/wordlists/dirb/big.txt
```

Comando de prompt 9 – Identificando Arquivos e Diretórios (6)
Fonte: Elaborado pelo autor (2021)

A saída do comando, com a inserção de porta diferente, retorna uma resposta diferente, pois ela constitui um serviço Web diferente e em uma porta diferente, conforme o Comando de Prompt “Identificando Arquivos e Diretórios (7)”.

```
└─$ dirb http://192.168.135.101:8080 /usr/share/wordlists/dirb/big.txt  
130 x
```

```
-----  
DIRB v2.22  
By The Dark Raver  
-----
```

```
START_TIME: Sun Feb 28 16:08:20 2021  
URL_BASE: http://192.168.135.101:8080/  
WORDLIST_FILES: /usr/share/wordlists/dirb/big.txt  
-----
```

```
GENERATED WORDS: 20458
```

```
---- Scanning URL: http://192.168.135.101:8080/ ----  
+ http://192.168.135.101:8080/[ (CODE:400|SIZE:1136)  
+ http://192.168.135.101:8080/] (CODE:400|SIZE:1136)  
+ http://192.168.135.101:8080/användare (CODE:400|SIZE:2359)  
+ http://192.168.135.101:8080/plain] (CODE:400|SIZE:1136)  
+ http://192.168.135.101:8080/quote] (CODE:400|SIZE:1136)  
+ http://192.168.135.101:8080/secci (CODE:400|SIZE:2359)
```

```
-----  
END_TIME: Sun Feb 28 16:08:57 2021  
DOWNLOADED: 20458 - FOUND: 6
```

Comando de prompt 10 – Identificando Arquivos e Diretórios (7)

Fonte: Elaborado pelo autor (2021)

São inúmeros diretórios encontrados que, em uma realização de Pentest Web, devem ser acessados e analisados com cuidado, identificando informações importantes e principalmente arquivos disponibilizados de forma incorreta. Todos os dados são muito importantes para a composição de relatórios e análises mais detalhados.

Buscando a demonstração básica de utilização da ferramenta Dirb, se utilizarmos o parâmetro “-X”, podemos filtrar as nossas buscas, visando à identificação de arquivos ocultos ou não no servidor, conforme o Comando de Prompt “Identificando Arquivos e Diretórios (8)”.

```
(root@kali)-[/home/jangow]
# dirb http://192.168.135.101:8080 -w /usr/share/wordlists/dirb/big.txt -X ".txt"

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Sun Feb 28 17:31:36 2021
URL_BASE: http://192.168.135.101:8080/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Stopping on warning messages
EXTENSIONS_LIST: (.txt) | (.txt) [NUM = 1]
```

Comando de prompt 11 – Identificando Arquivos e Diretórios (8)

Fonte: Elaborado pelo autor (2021)

Como exemplo, temos o seguinte endereço identificado: <http://192.168.135.101/002/passwords/accounts.txt>. Realizando um acesso ao arquivo em questão, observamos uma lista de usuários e senhas que provavelmente são credenciais de acesso a algum sistema interno, conforme a Figura “Identificando Arquivos e Diretórios (4)”.

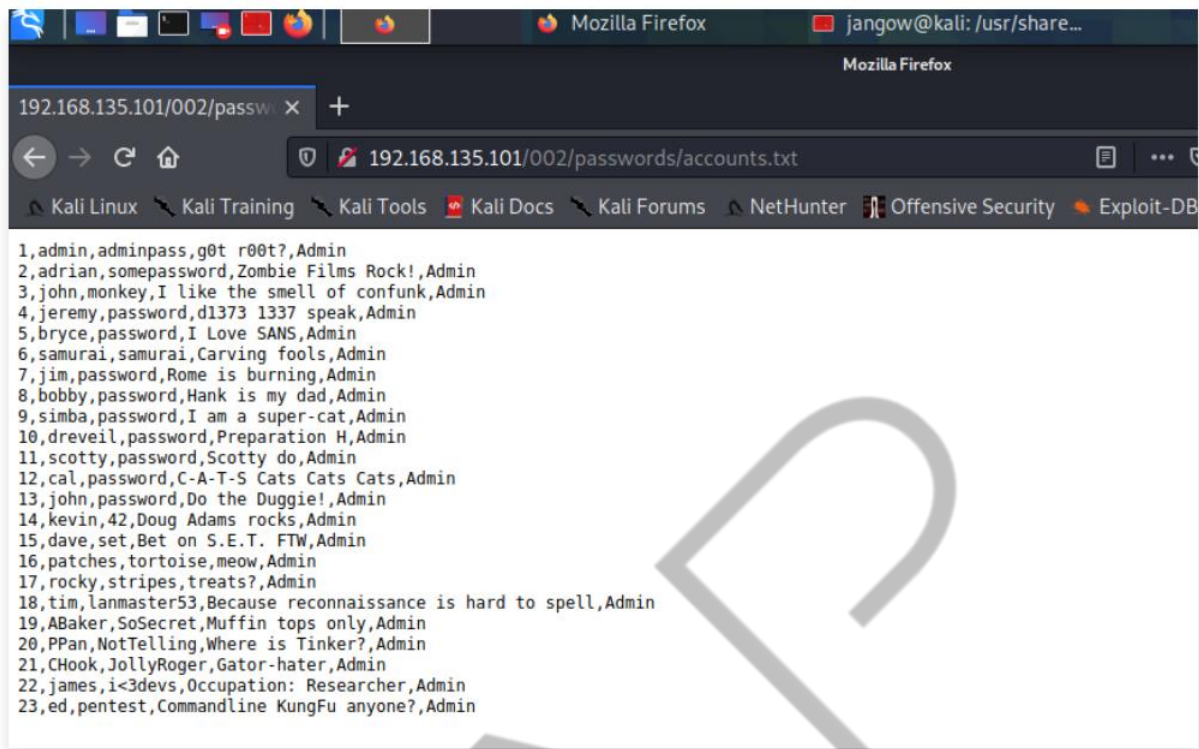


Figura 43 – Identificando Arquivos e Diretórios (4)

Fonte: Elaborado pelo autor (2021)

Na avaliação de um profissional de segurança, esse fato constitui uma falha de segurança gravíssima que pode comprometer uma aplicação, infraestrutura e muito mais.

4.2 Gobuster

Outra ferramenta muito importante para a identificação de diretórios e arquivos ocultos em serviços Web é o Gobuster.

Diferentemente do Dirb, o Gobuster possui muitos parâmetros de utilização que facilitam e retornam uma saída mais limpa e direta, como, por exemplo, a identificação de arquivos com extensões específicas ou diretórios como um todo.

O Gobuster é uma ferramenta muito prática e seu uso é muito simples. Sua sintaxe básica pode ser observada, conforme saída do Comando de prompt “Identificando Arquivos e Diretórios (9)”, realizando assim, uma descoberta simples de diretórios Web.

```
(root@kali)-[/home/jangow]
# gobusterdir -u 192.168.135.101 -w /usr/share/wordlists/dirb/big.txt
```

Comando de prompt 12 – Identificando Arquivos e Diretórios (9)

Fonte: Elaborado pelo autor (2021)

Na sintaxe aplicada, utilizamos o parâmetro “dir”, buscando identificar diretórios, “-u” para informar a url do alvo e “-w” para associarmos a wordlist desejada.

```
(root@kali)-[/home/jangow]
# gobusterdir -u 192.168.135.101 -w /usr/share/wordlists/dirb/big.txt
=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://192.168.135.101
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/big.txt
[+] Status codes: 200,204,301,302,307,401,403
[+] User Agent:    gobuster/3.0.1
[+] Timeout:      10s
=====
2021/02/28 16:40:30 Starting gobuster
=====
./htpasswd (Status: 403)
./htaccess (Status: 403)
/002 (Status: 301)
/007 (Status: 301)
/001 (Status: 301)
/images (Status: 301)
/javascript (Status: 301)
/phpmyadmin (Status: 301)
/server-status (Status: 403)
/test (Status: 301)
=====
2021/02/28 16:40:37 Finished
=====

(root@kali)-[/home/jangow]
#
```

Comando de prompt 13 – Identificando Arquivos e Diretórios (10)

Fonte: Elaborado pelo autor (2021)

Com uma execução rápida, o Gobuster possui um desempenho muito preciso e eficaz, identificando diretórios e os respectivos status de resposta do serviço Web.

Outra opção de utilização do Gobuster é usando o parâmetro “-e”, que retorna o endereço completo da verificação e do parâmetro “-s” de status, em que podemos filtrar os status que desejamos das aplicações, conforme o Comando de Prompt “Identificando Arquivos e Diretórios (11)”.

```
(rootkali)-[/home/jangow]
# gobusterdir -u http://192.168.135.101 -e -w /usr/share/wordlists/dirb/big.txt -s
"200,301,302,401"

=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://192.168.135.101
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/big.txt
[+] Status codes: 200,301,302,401
[+] User Agent:   gobuster/3.0.1
[+] Expanded:     true
[+] Timeout:      10s
=====
2021/02/28 16:53:35 Starting gobuster
=====
http://192.168.135.101/007 (Status: 301)
http://192.168.135.101/002 (Status: 301)
http://192.168.135.101/001 (Status: 301)
http://192.168.135.101/images (Status: 301)
http://192.168.135.101/javascript (Status: 301)
http://192.168.135.101/phpmyadmin (Status: 301)
http://192.168.135.101/test (Status: 301)
=====
2021/02/28 16:53:42 Finished
=====

(rootkali)-[/home/jangow]
#
```

Comando de prompt 14 – Identificando Arquivos e Diretórios (11)
Fonte: Elaborado pelo autor (2021)

Na opção acima, utilizamos os códigos de status “200, 301, 302 e 401”, obtendo, de uma forma mais limpa, a saída de resultados.

Uma opção muito interessante e muito utilizada é o parâmetro “-a”, no qual podemos inserir ou configurar um registro personalizado de “User-Agent”, que, em casos de Firewall de Aplicação, possui um resultado promissor no processo de *bypass* desse firewall.

Observando a Figura “Identificando Arquivos e Diretórios (5)”, vemos que, por padrão, o “User-Agent” resultante é a própria identificação da aplicação Gobuster.

```
(root@kali)-[/home/jangow]
└─# gobuster dir -u http://192.168.135.101:8080 -e -w /usr/share/wordlists/dirb/big.txt
=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://192.168.135.101:8080
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/big.txt
[+] Status codes: 200,301,302,401
[+] User Agent:    gobuster/3.0.1
[+] Expanded:     true
[+] Timeout:      10s
=====
```

Figura 44 – Identificando Arquivos e Diretórios (5)

Fonte: Elaborado pelo autor (2021)

Com a personalização do “User-Agent” e utilização do parâmetro “-a” no Comando de Prompt “Identificando Arquivos e Diretórios (12)”, o resultado pode ser observado, conforme a Figura “Identificando Arquivos e Diretórios (6)”

```
—(root@kali)-[/home/jangow]
└─# gobusterdir -u http://192.168.135.101 -e -w /usr/share/wordlists/dirb/big.txt -a "Teste 2021" -s "200,301,302,401"
```

Comando de prompt 15 – Identificando Arquivos e Diretórios (12)

Fonte: Elaborado pelo autor (2021)

```
(root@kali)-[/home/jangow]
└─# gobuster dir -u http://192.168.135.101 -e -w /usr/share/wordlists/dirb/big.txt -a "Teste 2021" -s "200,301,302,401"
=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://192.168.135.101
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/big.txt
[+] Status codes: 200,301,302,401
[+] User Agent:    Teste 2021
[+] Expanded:     true
[+] Timeout:      10s
=====
2021/02/28 16:59:49 Starting gobuster
```

Figura 45 – Identificando Arquivos e Diretórios (6)

Fonte: Elaborado pelo autor (2021)

Existem inúmeras configurações e personalizações de User-Agent, podendo ser encontrados sites que forneçam esses códigos, bastando inseri-los no comando da aplicação.

Outra disponibilidade de utilização do Gobuster é a identificação de arquivos, filtrados por extensões preestabelecidas, como: .php, .txt., .html, .asp, entre outros.

A identificação de arquivos, ocultos ou não, em plataformas Web pode trazer à tona uma falha extremamente grave, que inclui arquivos de configuração de aplicações, credenciais de acesso etc.

Para a utilização do Gobuster visando à identificação de arquivos, utilizamos o parâmetro “-x”, conforme o Comando de Prompt “Identificando Arquivos e Diretórios (13)”.

```
r dir -u http://192.168.135.101 -e -w /usr/share/wordlists/dirb/big.txt -s
"200,301,302,401" -x ".txt,.php,.asp,.html"
```

```
=====
Gobuster v3.0.1
```

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
```

```
=====
[+] Url:          http://192.168.135.101
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/big.txt
[+] Status codes: 200,301,302,401
[+] User Agent:   gobuster/3.0.1
[+] Extensions:  txt,php,asp,html
[+] Expanded:     true
[+] Timeout:      10s
=====
```

```
2021/02/28 17:25:34 Starting gobuster
```

```
=====
http://192.168.135.101/001 (Status: 301)
http://192.168.135.101/007 (Status: 301)
http://192.168.135.101/002 (Status: 301)
http://192.168.135.101/images (Status: 301)
http://192.168.135.101/index.html (Status: 200)
http://192.168.135.101/javascript (Status: 301)
http://192.168.135.101/phpmyadmin (Status: 301)
http://192.168.135.101/test (Status: 301)
=====
```

```
2021/02/28 17:26:08 Finished
=====
```

```

[~](root🐼kali)-[/home/jangow]
#
```

Comando de prompt 16 – Identificando Arquivos e Diretórios (13)

Fonte: Elaborado pelo autor (2021)

4.3 Nikto

A ferramenta Nikto, para profissionais Pentesters, constitui uma importante aliada para identificação de métodos, vulnerabilidades conhecidas e inúmeras outras informações.

Sua utilização é muito simples, não empregando a inserção de Wordlists. Para utilização básica e simples, retornando vários resultados, basta empregarmos o parâmetro “-h”, no qual apontaremos o endereço do host-alvo, conforme Comando de Prompt “Identificando Arquivos e Diretórios (14)”.

```
(root@kali)-[/home/jangow]
# nikto -h http://192.168.135.101
- Nikto v2.1.6

-----
+ Target IP:          192.168.135.101
+ Target Hostname:    192.168.135.101
+ Target Port:       80
+ Start Time:        2021-02-28 17:03:37 (GMT-4)
-----
+ Server: Apache/2.4.29 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ IP address found in the 'location' header. The IP is "127.0.1.1".
+ OSVDB-630: The web server may reveal its internal or real IP in the Location header via a request to /images over HTTP/1.0. The value is "127.0.1.1".
+ Server may leak inodes via ETags, header found with file /, inode: 359a, size: 594ed4b2a54be, mtime: gzip
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
+ Retrieved x-powered-by header: PHP/7.2.19-0ubuntu0.18.04.2
+ Uncommon header 'x-ob_mode' found, with contents: 1
+ OSVDB-3268: /test/: Directory indexing found.
+ OSVDB-3092: /test/: This might be interesting...
+ OSVDB-3268: /images/: Directory indexing found.
+ OSVDB-3233: /icons/README: Apache default file found.
+ /phpmyadmin/: phpMyAdmin directory found
+ 8069 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time:          2021-02-28 17:04:36 (GMT-4) (59 seconds)
-----
+ 1 host(s) tested
```

```
(root@kali)-[/home/jangow]
#
```

Comando de prompt 17 – Identificando Arquivos e Diretórios (14)

Fonte: Elaborado pelo autor (2021)

Analizando a saída dos resultados do Nikto, percebemos que a ferramenta retorna, além dos métodos permitidos na página em questão, conforme a Figura “Identificando Arquivos e Diretórios (7)”, a identificação de vulnerabilidades já conhecidas nos diretórios encontrados. O Nikto executa, de forma simples, parâmetros de identificação e análise do banco de vulnerabilidades.

```
(root@kali)-[/home/jangow]
# nikto -h http://192.168.135.101
- Nikto v2.1.6

-----
+ Target IP:      192.168.135.101
+ Target Hostname: 192.168.135.101
+ Target Port:    80
+ Start Time:     2021-02-28 17:03:37 (GMT-4)
-----
+ Server: Apache/2.4.29 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect a
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the con
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ IP address found in the 'location' header. The IP is "127.0.1.1".
+ OSVDB-630: The web server may reveal its internal or real IP in the Location header via a reque
+ Server may leak inodes via ETags, header found with file /, inode: 359a, size: 594ed4b2a54be, m
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the
+ Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
```

Figura 46 – Identificando Arquivos e Diretórios (7)

Fonte: Elaborado pelo autor (2021)

Visando à confirmação dos resultados, basta executarmos uma pesquisa simples no Google, contendo o código de vulnerabilidade mostrada, conforme a Figura “Identificando Arquivos e Diretórios (8)”.

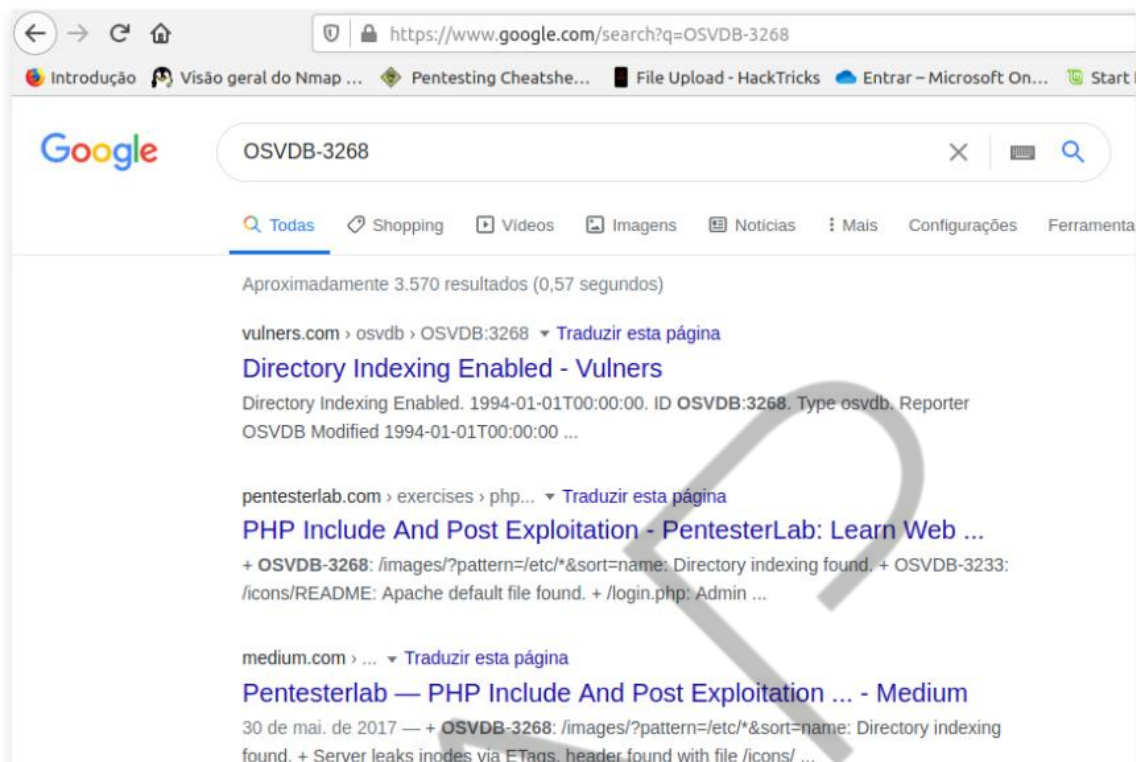


Figura 47 – Identificando Arquivos e Diretórios (8)

Fonte: Elaborado pelo autor (2021)

CONCLUSÃO

Diante do que foi demonstrado, reparamos o quão importante é a etapa de identificação de diretórios e arquivos. Por meio dos resultados obtidos, direcionamos os esforços de ataque e identificação de vulnerabilidades.

REFERÊNCIAS

GOOGLE CHROME. **Extensões.** [s.d]. Disponível em: <<https://www.google.com/intl/pt-BR/chrome/>>. Acesso em: 22 abr. 2021.

PORTSWIGGER. **Accelerate application security testing with Burp Suite.** [s.d]. Disponível em: <<https://portswigger.net/burp>>. Acesso em: 22 abr. 2021.

EMANIP